

T20 QA Results

Status

BLOCKED

T20 live deployment verification was not performed. No staging or production success is claimed, and no credential values, deployment identifiers, domains, metrics, or external service results were fabricated.

Prerequisite gate

The required deployment prerequisites are unavailable or unverifiable in this workspace:

- No separate staging secret store or populated staging target environment was found. `.env.staging.example` contains the required variable names but no usable target values.
- No separate production secret store or populated production target environment was found. `.env.production.example` contains the required variable names but no usable target values.
- A local `.env` exists and has populated entries, but its values were not read or printed and it does not establish which values belong to staging or production. It therefore cannot be treated as valid environment-specific deployment credentials.
- No process environment contains non-secret staging/production target or domain variables.
- No deployment target/provider configuration was found for the Node/Express

NestJS service. `package.json` has no staging/production deploy script; `wrangler.jsonc` contains only a D1 binding, with no application target, environment blocks, R2 binding, or custom-domain configuration. The `wrangler` executable is unavailable.

- No real staging or production domain/HTTPS endpoint was provided or found.
- T19 output (`DoneClaim` , `evidence-t19-happy.txt` , and `evidence-t19-failure.txt`) explicitly records that production credentials and infrastructure were unavailable and that live deployment remained T20.

Because `DB_DRIVER=d1` requires the three Cloudflare values and `STORAGE_DRIVER=r2` requires the four R2 values, the application cannot be started against the required staging or production services from this workspace. A deployment target, authenticated target identity, and real domains are also required for the staging-to-production and HTTPS checks.

T20 scenarios

Scenario	Result	Evidence
t20-happy : staging then production deployment and clean-account purchase/verify/activate/access/revoke/video/upload/login/logout/session-expiry checks	BLOCKED	No verifiable environment-specific D1/R2 credentials, deployment target identity, provider executable/configuration, or staging/production HTTPS domains
t20-failure : record failed checklist items before claiming completion	BLOCKED	Same prerequisite gate; no live endpoint was available to exercise

No live success is claimed. The blocked evidence records are `t20-happy.txt` and `t20-failure.txt` ; both explicitly state that no live endpoint was available and contain no secrets.

Local verification only

The following checks are local repository checks and do not substitute for T20 deployment verification:

- `npm run build`
- `npm run lint`
- `npm run test:esm`
- `npm run test:e2e`

Observed on 2026-09-12:

- `npm run build` exited 0.
- `npm run lint` exited 0.
- `npm run test:esm` passed 36 suites and 314 tests.
- `npm run test:e2e` passed 1 suite and 83 tests.
- LSP diagnostics could not run because the TypeScript LSP is not installed;

installation had previously been declined. Markdown has no configured LSP.

These results cover local code only. They do not change the BLOCKED status of the live deployment gate.

Unblock requirements

Xolvon Backend Documentation - qa-results.md

Provide separate staging and production secret stores containing valid D1, R2, JWT, and frontend URL values; provide the deployment provider/target, its authenticated access and executable/configuration; provide pre-migration backup/rollback and log access; and provide real HTTPS domains for both environments. The local .env must not be assumed to satisfy this gate.

After those prerequisites exist, T20 must deploy staging before production, run the complete checklist against clean accounts and real services, capture the resulting t20-happy and t20-failure evidence, monitor logs, and only then record a non-blocked result.

QA Addendum — Verifikasi Endpoint Lengkap Dua Target — 2026-09-13

Addendum ini adalah hasil eksekusi plan .omo/plans/xolvon-qa-endpoint-testing.md

(verifikasi endpoint penuh, dua target: LOKAL dan DEPLOYED). Bagian T20 lama di atas

TIDAK diubah — ini append-only sesuai aturan plan \$Must-NOT.

- Target LOKAL: http://localhost:3005/api (deviasi port — lihat §0.1)
- Target DEPLOYED: https://xolvon.canadev.my.id/api
- Seluruh nilai **Actual** pada tabel di bawah disalin VERBATIM dari artefak bukti

di .omo/evidence/xolvon-qa-endpoint-testing/ (direktori evidence yang sama untuk semua pointer). Tidak ada angka yang dikarang; sel Actual kosong = tidak ada.

- Format kolom milik addendum sumber: Endpoint | Skenario | Expected | Actual | Status | Catatan ;

Status ∈ {PASS, FAIL(→bug ID), BLOCKED-creds, N/A-adapted} (+label khusus yang tercatat

di artefak: N/A-DBAccess, N/A-noKeyAttachment, ENV-THROTTLE, DELEGATED-T13).

§0 Metode & deviasi (dicatat, bukan ditutupi)

1. **Deviasi port :3000 → :3005 (LOKAL).** :3000 dipegang proses MILIK USER —

hermes whatsapp-bridge (PID 1862; curl :3000/api menjawab 404 Express, bukan

Hello World!) — plus hazard ~/xolvon-local-supervisor.py (PID 12270→12635/12659)

yang crash-loop start:dev dan akan merebut :3000 begitu port lepas. QA TIDAK

membunuh proses milik user. Keputusan orchestrator (reversible): seluruh surface

lokal pindah ke PORT=3005 via shell-override. Bukti: task-1-preflight.txt

\$REDO Step 2 + \$FINISH 3005 (health Hello World! exact, lineage pid 24810→24834→24869).

2. **Shell-override DB_DRIVER=sqlite STORAGE_DRIVER=local-test (WAJIB) + INSIDEN seed→D1.**

.env mesin ini berisi DB_DRIVER=d1; npm run seed:admin TANPA override menulis

8 migrasi ke D1 REMOTE dan INSERT admin gagal 502 (task-1-preflight.txt \$ROOT CAUSE).

Nol perubahan data remote — INSERT gagal, hanya migration-bookkeeping remote tercatat.

Kontainmen: shell-override di SEMUA proses lokal (dotenv tidak menimpa process.env);

seed dengan override terbukti menulis LOKAL (local.db 319.488 B, admin count=1,

UNIQUE(user_id,course_id) ada). Bug produk terpetakan: **BUG-seed-driver** —

DIFIX di T16 (preflight refuse non-sqlite, commit 852f829→4c7d628).

3. **Reset DB baseline.** local.db pra-QA (0 byte) dipindah ke bukti

(local.db.pre-qa-1789270259), DB QA mulai dari nol → angka §3 bebas noise.

local.db dan .omo/ git-ignored (git check-ignore positif, task-1-preflight.txt Step 3/8).

4. **Cookie → Bearer (N/A-adapted).** Keputusan DL terkunci: login me-mint

{accessToken, refreshToken, user} di body, TANPA Set-Cookie. Baris "cookie flags"

di kedua target ditulis N/A — Bearer-only (keputusan DL terkunci), bukan PASS bohong.

5. **Path-divergence /admin/courses → /api/courses.** Matriks sumber menyebut

POST /admin/courses ; rute aktual = POST /api/courses + @Roles('admin')

(courses.controller.ts:87-145). Baris PATH-DIVERGENCE N/A-adapted di §2.2 kedua target.

6. **Referensi handbook diluruskan.** Matriks sumber "Handbook §7/§12" → otoritatif

aktual: **PRD §45** (kolom admin orders) dan **PRD §52** (publish gate);

juga **salah kutip awal** pada teks-task X1 ("q hilang → 400 per SearchQueryDto")

yang terbukti salah kutip: q ber-@IsOptional() → aktual 200 listing published

(F-T12-01, ter-reproduksi deployed).

7. **Metode HTTP.** curl di shell mesin ini me-mask ! pada body JSON → semua

panggilan ber-password memakai node-fetch driver (t6-driver.mjs dst).

Semua request mutasi TANPA header Origin / Sec-Fetch-Site → lolos

RequestIntegrityGuard (konvensi global plan); sub-check guard menolak

Origin: https://evil.example dieksekusi di T6 KEDUA target (403 + kontras 409).

8. **Pacing throttle.** register/login 5/menit/IP/route; grup signed/order 10/menit;

catalog/search 30/menit;Assertion A3 (429@ke-6) dipindah ke window sepi Wave-4 (T6b).

Newman lokal: ---delay-request 12000 + ---env-var baseUrl=http://localhost:3005/api

(tanpa delay, 75 request membakar budget auth → false-failure). Hasil: 0 ENV-THROTTLE

di T4; 4×429 recover-by-retry di T6-deployed (bukan bug produk).

9. Fingerprint deployed (T2): MATCH + kaveat TARGET-DATA#REPO-SEED. 8 probe

field-by-field => behavioral MATCH (envelope, pesan validator verbatim, key set, docs-json 404, health string) → deployed menjalankan build kontrak repo. 1 MISMATCH DATA: course-1 (non-UUID) + course-2 + admin admin-1 = seed out-of-band yang TIDAK ada di repo. Konsekuensi: semua fixture deployed dibuat sendiri via API (qa-*), id existing tidak pernah dipakai sebagai fixture.

10. **Karantina qa-*.** Semua mutasi deployed hanya mengenai entitas qa-* buatan run ini; exit karantina = unpublish/cancel terverifikasi response-surface (tidak ada API delete user/baris — residu tak-terekspos terdokumentasi per task).

11. Cross-lane review. Review ganda plan (momus + oracle) — sha256 transkrip IDENTIK 8b47f4f1c9b0c2dd58e941bdd1a5174def503f60abe8e3fe4fcd77fdbc7bca (no retrieval drift). Koreksi dual-review yang folded ke plan & dieksekusi: (B1) AD1 = 10-kunci + eksklusi DL-015 terkunci, bukan hard-fail 11 kolom; (B2) seed admin = ChangeMe-Admin-123! (bukan ChangeMe-Local-123! yang student); (B3) audit completeness TIDAK mid-wave → delegasi T13; (B4) assertion A3 429 → T6b window sepi Wave-4; (B5) newman --delay-request ; non-blocking: race-A boleh 500 sanitised (invariant DB penentu), guard grep -cF var kosong, sumber limit 5/min = @Throttle auth.controller.ts:48,59 (bukan grup named throttle.config.ts).

§L1 — Automated tests (T3, T4, T5)

T3 — jest LOKAL (repo build, mocked):

Perintah	Suites	Tests	Exit	Status	Catatan
npm run test:esm	44 passed / 44 total	411 passed / 411 total	0	PASS	task-3-esm.log ; noise stderr fetch failed *2 = assertion simulasi dalam test PASS
npm run test:e2e	1 passed / 1 total	107 passed / 107 total	0	PASS	task-3-e2e.log ; harness boot sendiri PORT 41234, mocked DB

Pasca-remediasi T16 (5 bug fix test-first, +14 test reproduksi/pinning): test:esm 46/46 suites, 425/425 tests; test:e2e 109/109 tests — exit 0, build exit 0 (task-16-final-suites.txt). Kedua angka disitasi: 44/411+107/107 = baseline pra-fix (T3), 425/109 = pasca-fix (T16). Doc-drift badge README (38/335) → §10.

T4 — newman collection penuh vs LOKAL (server :3005 hidup):

Perintah literal (deviasi port + delay documented):

npx newman run postman/xolvon-backend.postman_collection.json -e postman/environments/local.postman_environment.json --env-var baseUrl=http://localhost:3005/api --delay-request 12000

Metrik	Nilai	Status	Catatan
iterations	1 executed / 0 failed	PASS	durasi 15m 23s
requests	75 executed / 0 failed	PASS	runtime request failures nol
assertions	150 executed / 27 failed spanning 15 requests	FAIL(→BUG-T4-01..15)	klasifikasi di bawah; 0 request-level fail
429 / ENV-THROTTLE	grep -c 429 raw = 0	PASS	pacing 12s berhasil

Klasifikasi 27 assertion-fail (verdict T4: PARTIAL(15 product-bug candidates, 0 ENV-THROTTLE)):

- BUG-T4-01..13 = collection-asumsi-stale, produk BENAR: folder collection

mengasumsikan DB demo-seeded dengan content published (course-contoh dkk.) yang

sengaja tidak ada di baseline QA-reset, plus ordering bug intra-collection

(delete-lesson sebelum video-uri; {{memberId}} / {{enrollmentId}} placeholder

zero-UUID belum di-capture; cancel order PAID → 400 = justru sesuai matriks E9).

Semua actual (404/400/403) semantik benar per kontrak — lihat analisis RC per

request di task-4-newman-local.txt.

- BUG-T4-14/15 = kandidat produk terkuat (2 request): POST /admin/media/confirm

dan POST /admin/media/read-url membalas 201 vs assertion 200 — kontrak

docs/api-contract.md tidak mem-pin status sukses; Nest POST default 201.

Adjudikasi T17 (dokumentasikan 201 ATAU @HttpCode(200)) → §9 BUG-T4-14/15 OPEN-PARKED.

T5 — akses deployed + newman SMOKE vs DEPLOYED (hanya folder self-contained):

npx newman run postman/xolvon-backend.postman_collection.json -e <mktmp env LUAR repo> --folder "10, Newman Smoke" --delay-request 12000

Aspek	Actual	Status	Catatan
Login admin deployed	200, keys {accessToken,refreshToken,user}, user.role="admin", tanpa password_hash ; refresh opaque 64-hex NON-JWT; user.id legacy admin-1	PASS	gate "deployed admin usable for T6d-T12d: YES"; creds hanya env-shell, tidak pernah ke file
Register+login student qa	201/200, id UUID v4	PASS	karantina dipatuhi
X3 pre-check /auth/admin	200 admin / 403 student / 401 no-token	PASS	envelope verbatim repo
Newman smoke deployed	requests 9/9 executed, 0 failed; assertions 18 executed, 0 failed; exit 0; 0*429	PASS	durasi 1m51.6s; task-5-newman-smoke.txt
Teardown	temp env di mktmp -d LUAR repo → rm -rf receipt tercap	PASS	secret scan evidence 0 hit

Verdict: T5: PASS.

§2 Matriks manual dua target (§2.1–§2.7)

Kolom seragam milik addendum. Rows disalin dari evidence per-task; Actual/Status verbatim.

§2.1 Auth (mapping A1–A5; bukti task-6-auth-local.md + task-6b-throttle-local.md)

Target: LOKAL (http://localhost:3005/api)

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/auth/register	A1: register email valid (qa student baru, phone sesuai regex, name)	201 user baru dibuat	201 body SafeUserDto {"id":"be455027-...", "email":"qa-t6-a1-1789275196@example.test", "role":"user", "status":"active", ...}	PASS	—
POST /api/auth/register	A1: role FORCED user bahkan saat body menyertakan "role":"admin"	201 dengan role:"user" — role client tidak pernah dipercaya	400 {"statusCode":400,"message":["property role should not exist"],"error":"Bad Request",...}; SQL: rolestr_count=0 (tidak ada baris sama sekali)	PASS	Naik level dari expected: whitelist+forbidNonWhitelisted MENOLAK total (bukan diam-diam memaksa user); INSERT service hardcoded 'user' sebagai defense-in-depth
POST /api/auth/register	A1: varian role-injection role: ["admin"] (array)	tetap ditolak/dipaksa	400 {"statusCode":400,"message":["property role should not exist"],...}; SQL: rolearr_count=0	PASS	whitelist bekerja struktural, bukan per-type
POST /api/auth/register	A1: email duplikat	409/400 DAN SELECT COUNT(*) users WHERE email=... = 1	409 {"statusCode":409,"message":"An account with these credentials is already registered.",...}; SQL: dup_count=1	PASS	Pesan anti-enumeration generik (email ATAU phone)
POST /api/auth/register	A1: format invalid email/phone + password pendek (+ name kosong)	400 dengan pesan per-field	400 message array persis: ["Name is required.", "A valid email address is required.", "Phone number format is invalid.", "Password must be at least 8 characters long."]	PASS	collect-all 1 request
POST /api/auth/login	A2: login benar (student)	200 {accessToken, refreshToken, user}	200 {"accessToken":"eyJhbGciOi...", "refreshToken":"5d2bc50f...", "user":{...}} — ketiga kunci ada: user.role="user"	PASS	token di-mask sesuai aturan bukti
(cookie flags session)	A2: baris cookie flags login	cookie HttpOnly/Secure/SameSite	Tidak ada Set-Cookie; token di body	N/A-adapted	N/A — Bearer-only (keputusan DL terkunci) — mapping A2
sqlite3 sessions	A2: sessions menyimpan SHA-256, BUKAN token mentah	hash tersimpan	proof_stored_is_sha256_of_raw=1 (sha256(rawRefresh) == stored, match penuh 64-hex); proof_raw_never_stored=0; stored_len=64; raw refresh opaque 64-hex NON-JWT	PASS	Bukti kriptografis via SQL read-only LOKAL
response shape (jq keys)	A2: response tidak pernah memuat password_hash	absen	keys user login/register → password_hash present? false (login student & admin)	PASS	mapper toSafeUser strip
POST /api/auth/login	A2: login password SALAH	401 pesan ambigu anti-enumeration	401 {"statusCode":401,"message":"Invalid email or password.",...}	PASS	identik user-tidak-ada vs pw-salah
POST /api/auth/login	A3: 6x login salah/menit → 429 (limit aktual 5/menit)	ke-6 = 429	401,401,401,401,401,429 — burst 6x node-fetch (<35ms), replikasi identik di window sepi kedua (+72s) → deterministik; #6 = 429 ThrottlerException: Too Many Requests TOO_MANY_REQUESTS	PASS	Dieksekusi T6b Wave-4 window sepi; t6b-attempt1.txt + t6b-attempt2-recovery.txt; TTL-60s reset terbukti
GET /api/auth/me	A4: tanpa token	401 envelope	401 {"statusCode":401,"message":"Missing or invalid authorization token.",...,"error":"Unauthorized",...,"path":"/api/auth/me"}	PASS	—
GET /api/auth/me	A4: token garbage	401	401 {"statusCode":401,"message":"Invalid or expired token.",...}	PASS	—
GET /api/auth/me	A4: token format-expired (JWT exp lampau, struktural valid)	401	401 {"statusCode":401,"message":"Invalid or expired token.",...}	PASS	—
GET /api/auth/me	A4: token valid	200 user, tanpa password_hash	200 {"sub":"be455027-...", "email":"qa-t6-a1-...", "role":"user", "iat":1789275235, "exp":1789276135}	PASS	shape aktual = JwtPayload; deviasi bentuk dari kata "user" di matriks dicatat
POST /api/auth/logout → /api/auth/refresh	A5: logout lalu refresh token lama ditolak	logout 200; refresh lama → 401	200 {"message":"Logged out successfully."} → 401 {"statusCode":401,"message":"Invalid or expired refresh token.",...}	PASS	Inti matriks TERBUKTI. FINDING: GET /auth/me dengan access-JWT ≤15m SETELAH logout → 200 — BUG-T6-window (Medium, Open-Parked — denylist = surface baru, dilarang plan)
GET /api/auth/admin	X3: no token → 401 / student → 403 / admin → 200	401/403/200	401 Missing or invalid authorization token. / 403 You do not have permission to access this resource. / 200 {"message":"Admin access granted.", "user":{"sub":"85cf38c6-...", "role":"admin", ...}}	PASS	3 kategori satu window
POST /api/auth/register	GUARD: Origin: https://evil.example + Sec-Fetch-Site: cross-site pada mutasi	WAJIB ditolak RequestIntegrityGuard (bukti status+body)	403 {"statusCode":403,"message":"Request metadata is not allowed.", "error":"Forbidden",...}; SQL setelahnya: dup_count_after_guard=1 (mati di guard, tak pernah kena service/DB)	PASS	order guard Throttler → RequestIntegrity → pipe
POST /api/auth/register	GUARD presisi: POST IDENTIK tanpa Origin harus lolos ke jalur validasi	lolos guard (bukan 403)	409 An account with these credentials is already registered. (body sama persis, header saja berbeda)	PASS	kontras 403-409 = bukti presisi guard

Verdict LOCAL: 18/19 PASS · 1 N/A-adapted (cookie flags — DL terkunci) · 0 FAIL · 0 DEFERRED tersisa (A3 ditutup PASS via T6b) · FINDING: BUG-T6-window (Medium, Open-Parked)

Target: DEPLOYED (https://xolvo.canadev.my.id/api)

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/auth/register	A1: register email valid → 201	201 user baru dibuat	201 {"id":"b25803bf-0de1-...", "email":"qa-t6d-1789276585@example.test", "role":"user", "status":"active", ...} (seq01)	PASS	bukti response-only; uuid v4 (bukan "course-1" legacy) = dibuat build ini
POST /api/auth/register	A1: role-injection "role":"admin" → forced user	role tak pernah admin	400 {"statusCode":400,"message":["property role should not exist"],...} (seq02)	PASS	deployed identik lokal: ditolak total
POST /api/auth/register	A1: role-injection array	ditolak/dipaksa	400 {"statusCode":400,"message":["property role should not exist"],...} (seq09)	PASS	ENV-THROTTLE: 4x429 window register dibagi worker se-IP → tembus 400 pada retry-5 (bukan FAIL produk)
POST /api/auth/register	A1: email duplikat → 409/400 tanpa baris kedua	409/400	409 {"statusCode":409,"message":"An account with these credentials is already registered.",...} (seq04)	PASS	single-account dibuktikan response-only: 409 + re-login resolve TEPAT SATU id
POST /api/auth/register	A1: format invalid → 400 per-field	400 pesan per-field	400 message array persis: ["Name is required.", "A valid email address is required.", "Phone number format is invalid.", "Password must be at least 8 characters long."]	PASS	verbatim identik lokal
POST /api/auth/login	A2: login benar → 200 triple	200 {accessToken, refreshToken, user}	student 200 (seq10) & admin 200 (seq14) — {accessToken, refreshToken, user}; user.role = user / admin	PASS	login admin = satu-satunya pemakaian baris deployed yang ADA (legacy id admin-1). HANYA diautentikasi, tidak dimutasi
(cookie flags)	A2: cookie session flags	—	Tidak ada Set-Cookie; token di body	N/A-adapted	N/A — Bearer-only (keputusan DL terkunci); header login hanya access-control-allow-credentials:true
sessions hash	A2: SHA-256 di sessions	hash tersimpan	N/A-DBAccess — tanpa akses D1; bukti STRUKTURAL saja: raw refreshToken opaque 64-hex NON-JWT (student & admin)	N/A-DBAccess	hash-check TIDAK diklaim untuk deployed (mapping A2 — jujur)
response shape	A2: tidak ada password_hash	absen	keys user login → password_hash present? false (student & admin); body register likewise	PASS	diverifikasi dua peran deployed
POST /api/auth/login	A2: login salah → 401 ambigu	401 anti-enumeration	401 {"statusCode":401,"message":"Invalid email or password.",...} (seq12)	PASS	deployed = lokal
POST /api/auth/login	A3: ke-6 = 429	ke-6 = 429	401,401,401,401,401,429 — burst 6x node-fetch (span 2.1 s), #6 = 429 ThrottlerException: Too Many Requests — LAYER=APP/NestJS (amplop Nest verbatim, BUKAN html Cloudflare); header #1-#5 memuat x-ratelimit-limit: 5	PASS	T6b-DEPLOYED window IDLE attempt-1 bersih; edge CF tidak masking; t6bd-attempt1.txt

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /api/auth/me	A4: tanpa token → 401	401	401 {"statusCode":401,"message":"Missing or invalid authorization token.",_,,"path":"/api/auth/me"} (seq15)	PASS	—
GET /api/auth/me	A4: garbage → 401	401	401 {"statusCode":401,"message":"Invalid or expired token.",_,_} (seq16)	PASS	—
GET /api/auth/me	A4: expired → 401	401	401 {"statusCode":401,"message":"Invalid or expired token.",_,_} (seq17; JWT exp lampau + forged-sig)	PASS	—
GET /api/auth/me	A4: valid → 200 tanpa password_hash	200	200 {"sub":"b25803bf-...", "email":"qa-t6d-...", "role":"user", "iat":1789276716, "exp":1789277616} (seq18)	PASS	shape = JwtPayload; exp=iat+900 (15m)
POST /auth/logout → /auth/refresh	A5: invalidasi server-side + FINDING window	200→401; access JWT s15m 200	logout 200 (seq19) → refresh OLD 401 Invalid or expired refresh token. (seq20) → /auth/me access-JWT 200 (seq21)	PASS	BUG-T6-window PARITAS PERSIS dengan lokal — jendela s15m. no denylist — Open-Parked (owner); bukan FAIL matriks
GET /api/auth/admin	X3: 401/403/200	401/403/200	401 (seq22)/ 403 You do not have permission to access this resource. (seq23)/ 200 {"message":"Admin access granted.",_,_} (seq24)	PASS	3-kategori deployed lengkap
POST /api/auth/register	GUARD: Origin evil + cross-site → 403	WAJIB 403	403 {"statusCode":403,"message":"Request metadata is not allowed.",,"error":"Forbidden",_,,"path":"/api/auth/register"} (seq25)	PASS	guard menembak APP-layer deployed; request mati sebelum service (body sama dg baris dup → pasti 409 kalau lolos)
POST /api/auth/register	GUARD presisi: tanpa Origin lolos ke validasi	bukan 403	409 An account with these credentials is already registered. (seq04 — body IDENTIK, hanya header dihapus)	PASS	kontras 403→409 = presisi guard terbukti deployed

Verdict DEPLOYED: T6-DEPLOYED: 17/18 PASS, FAILS: [] – dalam 18 ada 1 N/A-adapted (cookie); di luar 18: 1 N/A-DBAccess (hash sessions); 0 DEFERRED tersisa (A3 PASS via T6b-DEPLOYED). Guard deployed PASS → tidak ada BUG-T6d-guard. BUG-T6-window terkonfirmasi PARITAS deployed. BUG-throttle-refresh-logout: bukti permukaan deployed x-ratelimit-limit: 100 pada /auth/refresh & /auth/logout (bukan 5/menit) → Medium, masuk T16.

\$2.2 Courses (mapping C1-C4; bukti task-7-courses-local.md + task-7-local/raw 33 file + task-7-deployed/raw)

Target: LOKAL — verdict baris: 15/16 PASS + 1 N/A-adapted (path-divergence), 0 FAIL.

Endpoint	Skenario	Expected	Actual	Status	Catatan			
GET /api/courses	C1-a katalog published-only: draft qa dibuat → absen; kontrol positif setelah publish	publik hanya published; q kosong → []; slug draft/absent → 404	Draft qa-t7-c1-draft-1789275270 (sqlite: draft) absen dari items. Saat cycle-course published (raw 12/27): statuses:["published"] . draft c1 tetap absen; saat unpublished (raw 24): present 0	PASS	raw 01,02,12,24,27			
GET /api/courses?q=	C1-b q tanpa cocokan → 200 items:{} bukan error	sama	HTTP 200, {"items": [],"total":0,"query":"zzqa-nomatch-nothing-1789275270"} (query di-echo)	PASS	raw 03			
GET /api/courses	C1-c pagination keys	sama	keys top-level [items,limit,page,query,total] ; page:1,limit:100,total:0..2 konsisten DL-011	PASS	raw 02			
GET /api/courses/:slug	C2-a slug DRAFT qa → 404, BUKAN datanya	user biasa 403; field wajib 400 per-field (kelompok C2)	HTTP 404, body = envelope, 0 kemunculan judul/description draft (grep). Pesan: "Course tidak ditemukan."	PASS	raw 04; kesetaraan draft#missing (courses.service.ts:100-102)			
GET /api/courses/:slug	C2-b slug random → 404 envelope lengkap, tidak pernah 500	sama	HTTP 404, keys [error,message,path,statusCode,timestamp]	PASS	raw 05			
POST /api/courses	C2-c student (role user) → 403	sama	HTTP 403 "You do not have permission to access this resource." . error Forbidden . path /api/courses ; DB: slug forged TIDAK terbentuk	PASS	raw 06			
POST /api/courses	C2-c+ (adjacent) tanpa token → 401	sama	HTTP 401 "Missing or invalid authorization token."	PASS	raw 07			
POST /api/courses	C2-d field wajib hilang ({}) → 400 pesan per-field	sama	HTTP 400 message[] 12 pesan verbatim: ["title maksimal 200 karakter.", "title tidak boleh kosong.", "title harus berupa teks string.", "slug maksimal 120 karakter.", "slug hanya boleh berisi huruf kecil, angka, dan tanda hubung.", "slug harus berupa teks string.", "description maksimal 5000 karakter.", "description tidak boleh kosong.", "description harus berupa teks string.", "price terlalu besar.", "price minimal 0.", "price harus berupa integer."]	PASS	raw 08; perilaku aktual dicatat, bukan dinilai FAIL			
POST /api/courses	C2-e field asing → 400 forbidNonWhitelisted	sama	HTTP 400, verbatim: message:["property evilField should not exist","property status should not exist"] → injeksi status:"published" juga diblok whitelist	PASS	raw 09; DB tidak ada baris terbentuk			
POST /api/courses/:id/publish → GET /api/courses → .../unpublish	C3-a siklus penuh draft→publish→muncul→unpublish→hilang→republish	Publish gate data belum lengkap (§12 → aktual PRD §52)	201 draft → publish 200 status:"published" → muncul di items (present 1) → unpublish 200 draft → hilang (present 0) → republish 200. Setiap transisi punya row audit	PASS	raw 10–17,23–27,32.*			
POST /api/courses/:id/publish	C3-b gate incomplete → ditolak sesuai field wajib aktual	sama	Gate AKTUAL = assertPublishable: hanya description + price. Terbukti MENYALA: description:" " (whitespace, lolos create DTO tidak trim) → publish → HTTP 400: "Course belum lengkap untuk dipublish. Field wajib belum ada: description." → setelah PATCH description valid → publish 200. Publish yang ditolak gate TIDAK menulis row audit	PASS	raw 19–22: FINDING: cabang price tak terjangkau API (NOT NULL + @IsInt); 400 per-field 12 pesan			
POST /api/courses/:id/publish	C3-c publish oleh student → 403	sama	HTTP 403 "You do not have permission to access this resource."	PASS	raw 18			
POST /api/courses/:id/publish	C3-d (adjacent) publish ulang yang sudah published	sama	HTTP 400 "Course sudah berstatus published." (strict transition)	PASS	raw 14			
GET /api/courses/:slug	C4 detail publik tanpa video_object_key /signed URL — bahkan setelah lesson dibuat	raw video_object_key tak pernah muncul publik	POST lesson → 201 (DB video_object_key=NULL). Detail 200: scan forbidden [] ; scan leak text `video_object_key`	local-storage.test	X-Amz\ Signature\ content = 0 hit. Kontras: respons ADMIN 201 memang memuat videoObjectKey:null' → stripping di level DTO publik	Signature\	content = 0 hit. Kontras: respons ADMIN 201 memang memuat videoObjectKey:null' → stripping di level DTO publik	P
GET /api/home	Cross-check T7: draft qa tidak bocor ke home	— (tugas T7; logika penuh T12)	Home #1: 4/4 slug draft 0 hits, hanya published yang muncul; Home #2 pasca-teardown: qa_t7_slugs: []	PASS	raw 31,33			

Endpoint	Skenario	Expected	Actual	Status	Catatan
Xqlvva Backend Documentation - qa-results and POST /api/admin/courses (matriks literal)	PATH-DIVERGENCE: matriks menyebut /admin/courses	POST /admin/courses → —	Rule literal tidak ada; aktual POST /api/courses + @UseGuards(AuthGuard, RolesGuard) @Roles('admin')	N/A- adapted	courses.controller.ts:87- 145; seluruh C2/C3 dieksekusi di rute aktual

Target: **DEPLOYED** — verdict verbatim: T7-DEPLOYED: 13/13 PASS, FAILS: [] (baris PATH-DIVERGENCE N/A-adapted; C3-c & CROSS-home & QUARANTINE receipt tambahan, semua PASS).

Endpoint	Skenario	Expected	Actual	Status	Catatan			
GET /courses	C1-a published-only + draft qa absen	publik hanya published; q kosong → []; slug draft/absent → 404	HTTP 200; 1 item, statuses= ["published"] (asing course-1 tampil — tidak disentuh). Draft qa sendiri dibuat DRAFT dan tetap absen di semua snapshot; pasca- teardown. 0 slug qa-t7d	PASS	raw 04.17.19.30.31; kaveat T2 TARGET- DATA#REPO- SEED			
GET /courses?q=	C1-b q tanpa cocok → 200 []	sama	HTTP 200, {"items": [], "total":0, "query": "zz-no-match- 1789276600"} (query di-echo)	PASS	raw 05			
GET /courses	C1-c pagination keys	sama	keys top-level [items, limit, page, query, total]; page:1 limit:100 total:1 (DL-011). Baris API- created = UUID v4 (381ffd46-...) → course-1 non- UUID = murni seed → kaveat T2 TERKONFIRMASI	PASS	raw 04.06.15			
GET /courses/:slug	C2-a slug draft → 404 bukan data	user biasa 403; field wajib 400 per-field	HTTP 404 "Course tidak ditemukan." ; scan body: 0 kemunculan title/description draft sendiri	PASS	raw 07			
GET /courses/:slug	C2-b slug random → 404 envelope, bukan 500	sama	HTTP 404 (BUKAN 500), envelope keys tepat [error, message, path, statusCode, timestamp]	PASS	raw 08			
POST /api/courses	C2-c student 403	sama	HTTP 403 "You do not have permission to access this resource." ; follow-up GET slug forged → 404	PASS	raw 09.10; student = akun sendiri di- register via API			
POST /api/courses	C2-c+ no-token 401	sama	HTTP 401 "Missing or invalid authorization token."	PASS	raw 11			
POST /api/courses	C2-d 400 per-field verbatim	sama	HTTP 400 message[] 12 pesan — IDENTIK lokal, verbatim (title/slug/description/price; lihat label LOKAL C2-d)	PASS	raw 12			
POST /api/courses	C2-e extra field verbatim	sama	HTTP 400, verbatim: message:["property evilField should not exist", "property status should not exist"] → injeksi status diblok; follow-up GET → 404	PASS	raw 13,14			
POST /api/courses/:id/publish siklus	C3-a draft→publish→muncul→unpublish→hilang→republish	Publish gate (PRD §52)	create 201 draft → publish 200 → ?q= hits 1 → unpublish 200 draft → hits 0 → republish 200 → UNPUBLISH akhir 200 draft (karantina)	PASS	raw 15-20 + 29			
POST /api/courses/:id/publish	C3-b gate incomplete	sama	Create description:" " → 201 draft → publish → HTTP 400 verbatim: "Course belum lengkap untuk dipublish. Field wajib belum ada: description." — persis repo build, TIDAK ada delta build deployed	PASS	raw 26.27; course gate ditinggal DRAFT			
POST /api/courses/:id/publish	C3-c non-admin 403	sama	HTTP 403 (student)	PASS	raw 22			
POST /api/courses/:id/publish	C3-d double-publish 400	sama	HTTP 400 "Course sudah berstatus published." (identik lokal)	PASS	raw 21			
GET /courses/:slug	C4 tanpa video_object_key/signed URL pasca lesson	raw video_object_key tak pernah muncul publik	Detail PUBLIK 200: recursive scan forbidden hits [] ; leak- fragment scan ("video_object_key")	videoObjectKey	X-Amz	Signature=	r2.cloudflarestorage	sign cle /cou → 2 DR/
GET /home	Cross-check draft qa absen	—	HTTP 200; slug DRAFT qa-t7d ABSEN; receipt akhir: 0 substring qa-t7d di /home	PASS	raw 28,32			
POST /admin/courses (literal)	PATH-DIVERGENCE	POST /admin/courses → —	rule aktual POST /api/courses +admin guard; dikonfirmasi deployed: pesan verbatim identik repo	N/A-adapted	sama utk kedua target			

Karantina exit deployed: katalog kembali persis kondisi awal (total published=1 milik asing course-1), 3 course qa-t7d + lesson berakhir DRAFT, /home & /courses bersih dari qa-t7d .

§2.3 Lessons/Media/Upload (mapping M1-M3 + X2 + LESSONS; bukti task-8-media-local.md + task-8-local/raw 53 + task-8-deployed/raw 49)

Target: **LOKAL** — verdict verbatim: T8-LOCAL: 30/34 PASS, 4 N/A-adapted(stub-driver), FAILS: []

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/admin/media/upload-url	M1.1 contentType text/html → ditolak SEBELUM presign	MIME/size ditolak sebelum presign; non-admin 403	HTTP 400, verbatim: "contentType must be one of the following values: image/jpeg, image/png, image/webp, application/pdf, video/mp4" — body TIDAK memuat key / uploadUrl	PASS	raw 08
POST /api/admin/media/upload-url	M1.2 size 524288001 > MAX 524288000	sama	HTTP 400 "size must not be greater than 524288000". tanpa key/uploadUrl	PASS	raw 09
POST /api/admin/media/upload-url	M1.3 prefix private/secret (di luar MEDIA_PREFIXES)	sama	HTTP 400 "prefix must be one of the following values: public/site, public/projects, private/projects, private/courses"	PASS	raw 10
POST /api/admin/media/upload-url	M1.4 student token	non-admin 403	HTTP 403 "You do not have permission to access this resource."	PASS	raw 11
POST /api/admin/media/upload-url	M1.5 tanpa token	AD3: 401	HTTP 401 "Missing or invalid authorization token."	PASS	raw 12
POST /api/admin/media/upload-url	M2a happy: filename ".../EVIL-name.png" → key = \${prefix}/\${uuid}.ext BUKAN nama file	key server- generated	HTTP 201 {key:"private/projects/dcfbc54-...png", uploadUrl:"http://local-storage.test/upload/_", expiresIn:3600} ; key regex uuid v4 TRUE; EVIL TIDAK ada di key	PASS	raw 13; deviasi 201 vs teks-task 200 = F-T8-07 (→ BUG-T4-14/15 family)
PUT uploadUrl	M2b: upload nyata bytes 1x1 PNG ke presigned URL	upload PUT nyata	fetch failed – ConnectTimeoutError: attempted address local-storage.test:80 (network error, BUKAN respons HTTP) — driver local-test = stub, bytes tidak pernah mendarat	N/A-adapted	raw 14; F-T8-01; byte-level equivalence dibuktikan di DEPLOYED (T8d)

Endpoint	Skenario	Expected	Actual	Status	Catatan
<code>POST /api/admin/media/confirm</code>	M2c {key} → sukses	confirm alur penuh	HTTP 201 {key:"private/projects/dcfbc54-...png", confirmed:true} — TANPA validasi eksistensi objek: PUT barusan GAGAL di network, tetap "confirmed"	PASS (kontrak)	raw 15; integritas → F-T8-03 / BUG-T8-01 (→ §9)
DB: tabel metadata media	M2c-db proof: SELECT baris metadata untuk key	key terekam DB == key server-generated	Tabel media TIDAK ADA (.tables + DDL 0000-0007: nol); MediaService.confirm tidak menulis DB; substitusi persistensi yang ADA: course_resources.object_key	N/A-adapted (DOC-DRIFT PROVEN)	raw 18,40; README "register object metadata" = drift (F-T8-02 → §10)
<code>POST /api/admin/media/confirm</code>	M2c-edge traversal private/projects/./secret.png & key etc/passwd	negatif control	400 "Invalid media key." keduanya (gate isServerKey)	PASS	raw 16,17
<code>POST /api/admin/media/read-url</code>	M2d {key} valid → readUrl	alur M2	HTTP 201 {readUrl:"http://local-storage.test/read/...", expiresIn:300}	PASS	raw 19; 201-not-200 F-T8-07
<code>POST /api/admin/media/read-url</code>	M2d2 key invalid	sama	HTTP 400 "Invalid media key."	PASS	raw 20
GET readUrl + sha256	M2e: bytes hasil baca == sha256 file asal (c414cd0e...)	bytes match	TIDAK TERUJI di lokal: GET → ConnectTimeoutError (identik M2b); stub tidak menyipkan bytes → round-trip mustahil oleh desain driver	N/A-adapted	raw 21; sha256 sumber dipakai utk uji deployed
GET objek private TANPA signed query	M3: akses private/... tanpa signed → 403 storage	lokal: perilaku driver dicatat setara/beda	BEDA (bukan setara): driver lokal tidak punya signature untuk di-strip — unsigned===signed TRUE (0 query param); GET raw path → ConnectTimeoutError; enforcement-gap lokal BERBASIS KODE, bukan asumsi	N/A-adapted (LAPOR GAP)	raw 21,22; F-T8-01; uji R2 mentah = T8d deployed
lessons.is_preview FALSIFI	Klaim README "free preview bypass"	faktakan kolom/branch	(1) PRAGMA table_info(lessons) TANPA is_preview; (2) scan getVideoUrl tanpa branch preview; (3) student GET /lessons/<id>/video-url → 404 "Video lesson tidak ditemukan." — BUKAN 200-signed	PASS (falsifikasi)	raw 23,24,25; DOC-DRIFT TERBUKTI (F-T8-05 → §10)
<code>PATCH /api/lessons/:id</code>	L1 admin ubah title	lesson CRUD admin	HTTP 200, title berubah, videoObjectKey:null, status draft	PASS	raw 26
<code>PATCH /api/lessons/:id</code>	L2 student → 403	user → 403	HTTP 403 permission message	PASS	raw 27
<code>PATCH /api/lessons/:id</code>	L3 injeksi {"videoObjectKey":"private/projects/evil.png"}	edge whitelist	HTTP 400 "property videoObjectKey should not exist" → key TIDAK bisa dipasang via PATCH	PASS	raw 28; proyeksi bukti F-T8-04
<code>PATCH /api/lessons/:id/reorder</code>	L4 {orderIndex:5}	reorder admin	HTTP 200 orderIndex 5; DB order_index=5	PASS	raw 29,34
<code>PATCH /api/lessons/:id/reorder</code>	L5 {orderIndex:-1} → 400	400	HTTP 400 "orderIndex minimal 0."	PASS	raw 30
<code>POST /api/lessons/:id/publish</code>	L6 publish	CRUD+publish admin	HTTP 200 status:"published"	PASS	raw 31
<code>POST /api/lessons/:id/publish</code>	L7 publish ulang	400	HTTP 400 "Lesson sudah berstatus published."	PASS	raw 32
<code>POST /api/lessons/:id/unpublish</code>	L8 unpublish (karantina akhir)	—	HTTP 200 status:"draft" — kembali draft	PASS	raw 33
lessons.video_object_key state	Rekam kondisi null	key null	Semua respons lesson: videoObjectKey:null; DB <NULL>; TIDAK ADA rute API yang dapat mengisi key	PASS	raw 06,07,26-35,51; F-T8-04 — blokir struktural E4 (→ §2.4 PROMOSI)
GET /api/courses/:slug (adjacent)	L10 course qa-t8 draft → 404 publik	regression	HTTP 404 "Course tidak ditemukan."	PASS	raw 35
<code>POST /api/lessons/:lessonId/resources</code>	X2a admin valid (type pdf, objectKey = key M2, title)	create valid	HTTP 201; DB row persist penuh, object_key = key server-generated	PASS	raw 36,40; detail → §8 X2
<code>POST /api/lessons/:lessonId/resources</code>	X2b student	non-admin 403	HTTP 403	PASS	raw 37
<code>POST /api/lessons/:lessonId/resources</code>	X2c type:"quiz"	invalid → 400	HTTP 400 verbatim: "type hanya boleh salah satu dari: pdf, resource, assignment."	PASS	raw 38
<code>POST /api/lessons/:lessonId/resources</code>	X2c2 body {}	invalid → 400	HTTP 400, 7 pesan per-field	PASS	raw 39
<code>DELETE /api/resources/:id</code>	X2d admin delete → 2xx + DB gone	delete	HTTP 200 (echo baris terhapus) + SELECT COUNT(*) WHERE lesson_id=ours → 0	PASS	raw 41,42
<code>DELETE /api/resources/:id</code>	X2e id sendiri lagi / id asing	asing → 404	Re-DELETE id sendiri → 404 "Resource tidak ditemukan."; random-UUID v4 → 404	PASS	raw 43,44,45
<code>POST /api/lessons/:lessonId/resources</code>	X2e4 lessonId UUID tak dikenal	edge	HTTP 404 "Lesson tidak ditemukan."	PASS	raw 46
GET /api/courses?limit=100	REG adjacent: katalog sehat pasca mutasi; qa-t8 absen	regression	HTTP 200 {items:[],page:1,limit:100,total:0,query:null} — 0 slug qa-t8	PASS	raw 47,49
GET /api/home	REG adjacent	regression	HTTP 200 empty-shape wajar	PASS	raw 48

Target: **DEPLOYED** — verdict verbatim: T8-DEPLOYED: 12/14 PASS, FAILs: [BUG-T8d-01 (X2a resource-create 502 deterministik deployed; memblokir leg happy-path X2d)] . Kelompok inti R2 (M1-M3): **10/10 PASS** — keempat N/A-adapted lokal naik ke bukti nyata.

Endpoint	Skenario	Expected	Actual	Status	Catatan
<code>POST /admin/media/upload-url</code>	M1.1 contentType text/html → 400 pra-presign	MIME/size ditolak sebelum presign; non-admin 403	HTTP 400, verbatim: "contentType must be one of the following values: image/jpeg, image/png, image/webp, application/pdf, video/mp4" — body TANPA key/uploadUrl	PASS	raw 06; pesan identik byte-per-byte dgn lokal
<code>POST /admin/media/upload-url</code>	M1.2 size > 524288000 → 400	sama	HTTP 400 "size must not be greater than 524288000", tanpa key/uploadUrl	PASS	raw 07
<code>POST /admin/media/upload-url</code>	M1.3 prefix disallowed → 400	sama	HTTP 400 "prefix must be one of the following values: public/site, public/projects, private/projects, private/courses"	PASS	raw 08
<code>POST /admin/media/upload-url</code>	M1.4 student → 403	non-admin 403	HTTP 403 "You do not have permission to access this resource."	PASS	raw 09
<code>POST /admin/media/upload-url</code>	M1.5 no-token → 401	AD3	HTTP 401 "Missing or invalid authorization token." (401 bukan 403 — AD3 terpenuhi)	PASS	raw 10

Endpoint	Skenario	Expected	Actual	Status	Catatan	
POST /admin/media/upload-url	M2a filename jahat → key uuid server	key = \${prefix}/\${uuid}.ext	HTTP 201 {key:"private/projects/52247ee0--.png", uploadUrl:"https://xolvon-course-storage-staging-r2.cloudflarestorage.com/~7X-Amz-Algorithm=AWS4-HMAC-SHA256..", expiresIn:3600}; key regex uuid v4 TRUE; EVIL / .. TIDAK ada di key	PASS	raw 11; 201-bukan-200 = F-T8-07 paritas	
PUT uploadUrl (R2)	M2b bytes nyata 200	upload PUT nyata	HTTP 200 + etag:"2cd8bde4..". server: cloudflare. cf-ray → 70 B PNG MENDARAT DI R2 NYATA. BUKTI UPLOAD PERTAMA yang mustahil di lokal; TTL presign PUT terverifikasi dari surface: X-Amz-Expires=3600	PASS	raw 12; gap F-T8-01 CLOSED	
POST /admin/media/confirm	M2c (key) → 2xx; edge traversal/foreign → 400	sama	{key} nyata → HTTP 201 {key, confirmed:true}; kontrol fabricated key (TIDAK PERNAH di-PUT) → juga 201 {confirmed:true} → confirm TETAP tidak memvalidasi eksistensi objek di R2 nyata; traversal & etc/passwd → 400 "Invalid media key."	PASS (kontrak)	raw 13-16; DB-metadata sub-baris = N/A-DBAccess; F-T8-02 persists lintas target	
POST /admin/media/read-url + GET	M2d readUrl + bytes sha256 match	GET it → bytes match sha256	read-url → 201 {readUrl, expiresIn:300} (SigV4, X-Amz-Expires=300 terlihat); GET signed → 200. content-type: image/png. 70 bytes, sha256 = c414cd0e.. == sumber → PLAYABLE PROVEN di R2 nyata; key invalid → 400 "Invalid media key."	PASS	raw 17-20; gap F-T8-01/M2e CLOSED	
GET raw R2 TANPA signed query	M3 → 403/AccessDenied storage	akses private tanpa signed → ditolak storage	query di-strip → DITOLAK storage: HTTP 400 <Code>InvalidArgument</Code> <Message>Authorization</Message> (deviasi kode-status dari literal "403 AccessDenied" dicatat, DENIAL tercapai — nol bytes); kontrol tamper 1 char signature → HTTP 403 SignatureDoesNotMatch	PASS	raw 21,22; unsigned===signed FALSE (kontras lokal TRUE); bukti level-storage yang mustahil diberikan stub lokal	
PRAGMA/D1 + video-url student	is_preview falsify (kolom + branch + surface 404)	sama	student (tanpa enrollment, lesson draft) GET /lessons/<id>/video-url → 404 "Video lesson tidak ditemukan." → verbatim identik lokal (branch null-key sebelum enrollment). Sub-baris skema kolom = N/A-DBAccess	PASS (surface-only)	raw 23; falsifikasi kolom tetap dari bukti lokal	
PATCH /lessons/:id +reorder/publish/unpublish	L1-L8 matriks lesson CRUD	CRUD admin; user → 403	L1 title→200; L2 student→403; L3 injeksi videoObjectKey→400 "property videoObjectKey should not exist"; L4 reorder 5→200; L5-1→400 "orderIndex minimal 0."; L6 publish→200; L7 ulang→400 "Lesson sudah berstatus published."; L8 unpublish→200 draft (karantina akhir). Semua pesan verbatim identik lokal	PASS	raw 24-31; hanya lesson milik course qa-t8d sendiri	
POST /lessons/:id/resources	X2a/b/c 201/403/400	create non-admin 403, valid	X2a FAIL — BUG-T8d-01 (deployed-only): admin valid → HTTP 502 deterministik 5/5 (halaman error edge Cloudflare "canadev.my.id \	502: Bad gateway , BUKAN envelope JSON aplikasi). Rute HIDUP di lapisan lain: X2b student → 403; X2c type="quiz" → 400 verbatim; X2c2 'j' → 400 7 pesan. GET list resource: rute tidak ada by design	FAIL	raw 32-35,44-49; lokal = 201 → DEFECT KHUSUS DEPLOYED; kandidat akar (T16/owner): drift skema/worker di jalur INSERT course_resources deployed — verifikasi butuh akses D1/worker-log
DELETE /resources/:id	X2d/e 200+gone / 404	delete; id asing → 404	Leg happy-path tidak tercapai — diblokir BUG-T8d-01 (tidak ada baris yang bisa dihapus). Leg error TERBUKTI: DELETE id non-UUID → 400 "Validation failed (uuid v4 is expected)"; random UUID v4 → 404 "Resource tidak ditemukan."; create ke lesson UUID asing → 404	FAIL	raw 36-39; mumi dependensi baris yang gagal tercipta oleh bug di atas	

Catatan deployed-parity: FINDING F-T8-03 (confirm tanpa HEAD-check) KINI TERBUKTI DI ATAS R2 NYATA (kontrol dua sisi key nyata vs fabricated → sama-sama 201) → BUG-T8-01 tetap Open-Parked (→ \$9). Residual jurur: 1 objek R2 70 B penanda QA tak terhapus (tidak ada endpoint delete objek — by design).

\$2.4 Enrollments/Orders/Signed-URL (mapping E1-E10 — PALING KRITIKAL; bukti task-9-critical-local.md + task-9-local/raw 48 + task-9-deployed/raw 52)

Target: LOKAL — verdict verbatim: T9-L0CAL: 19/20 PASS + 1 N/A-adapted (E6 driver-caveat – satu-satunya caveat diizinkan acceptance), FAILs: [], E8: EXPLOIT-TERBUKTI.

Fixture-method WAJIB diingat saat membaca bukti E4/E6: video_object_key mustahil diisi

via API (F-T8-04) → SATU UPDATE lessons SET video_object_key=_ WHERE id=<lesson qa-t9>

sqlite terlabel (receipt raw/s2-db-lesson.txt).

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/orders	E1a (L1) order pertama course published (A)	201 pending, amount server-side	201; amount=150000 == SELECT price FROM courses =150000; DB: order '22deb73e..')	150000)	pending)
POST /api/orders	E1b (L2) order ULANG course yang sudah enrollment ACTIVE	amati perilaku nyata	201 order baru b57ce3a1.. pending; DB pending A+course: 0→1	PASS (observasi)	[OPEN DECISION] — checkout TIDAK cek enrollment aktif/duplikat/status published; order dup dibatalkan di teardown; aturan tidak di-invent
POST /api/orders/:id/payment-proof	E2a (L3) proof objectKey arbitrer (private/courses/whatever.png)	diterima (DTO hanya string)	201 {message:"Bukti pembayaran berhasil diunggah.",proofId}:row payment_proofs tercatat	PASS	persis prediksi DTO
payment-proof	E8 (L4) traversal key ../../etc/passwd	amati	201 diterima, row DB object_key ../../etc/passwd	PASS (probe)	bagian verdict E8
payment-proof	E8 (L5) traversal percent-encoded ../../..%2f..%2fprivate%2fcourses%2fx.png	amati	201 diterima	PASS (probe)	
payment-proof	E8 (L6) PROBE kunci lintas-user: A submit objectKey milik B	amati; diterima = EXPLOIT	A: 201 diterima (proofId 370b3dac..); B: 201 milik sendiri. DB: kedua baris payment_proofs memakai object_key yang sama, uploaded_by user berbeda	PASS (probe)	E8: EXPLOIT-TERBUKTI (write-surface) → BUG-T9-01; raw dua sisi tersimpan
payment-proof	E7-guard adjacent (L7) B submit proof ke ordernya A	403 (order-IDOR guard)	403 Anda tidak memiliki akses ke order ini.	PASS	guard ORDER-ownership ADA; yang TIDAK ada = validasi KEY (L6)
PATCH /api/orders/:id/verify	E2b (L8) admin verify pending→paid	200 paid + audit	200 status=paid; DB verified_by=<admin>; audit row verify	PASS	

Endpoint	Skenario	Expected	Actual	Status	Catatan	
verify	E2c (L9) verify order CANCELLED	4xx state-machine	400 "Order yang sudah dibatalkan tidak dapat diverifikasi."	PASS		
POST /api/orders/:id/cancel	E9 (L10) cancel order PAID; cancel DUA KALI	4xx konsisten	cancel-paid: 400 "Hanya order berstatus pending yang dapat dibatalkan." ; double-cancel: 400 pesan sama; pending→cancelled: 200	PASS	state machine satu arah	
POST /api/orders/:id/activate	E3 (L11) activate lalu activate LAGI (sekuensial)	200; enrollment tetap 1	#1 200 {activatedCoursesCount:1}; #2 200 body identik; DB COUNT enrollments (A,C1) = 1; /enrollments/me: 1 baris active	PASS	UPsert ON CONFLICT.FINDING minor: aktivasi ke-2 tetap menulis audit row ke-2 & count tetap 1 padahal no-op (FIND-T9-05)	
GET /api/lessons/:id/video-url	E4 (L12) TANPA enrollment	403	403 "Enrollment aktif diperlukan." (A & B)	PASS		
video-url	E4 (L13) DENGAN enrollment active: mint + GET URL	200 {videoUrl, expiresIn:300}; URL playable	200 {"url":"http://local-storage.test/read/private/courses/qa-t9-...mp4","expiresAt":"-"}; GET url → gagal resolusi DNS	PASS dengan 2 catatan	(1) deviasi bentuk kontrak {url, expiresAt} BUKAN {videoUrl, expiresIn} — prompt salah, kode otoritatif (FIND-T9-03 → §10); (2) local-test driver → "playable" tak terdefinisi lokal (FIND-T9-04); padanan R2 = DEPLOYED/T8d	
video-url	E4c (L14) setelah enrollment REVOKED, minta ulang	403 (cek per request)	403 "Enrollment aktif diperlukan." ; DB: enrollment'a2ce9380...)	revoked	PASS	entitlement diverifikasi per request, bukan cache
video-url	E5 (L15) IDOR: B minta lesson course yang HANYA A ikuti	403/404	403 "Enrollment aktif diperlukan."	PASS		
GET signed URL expired	E6 (L16) mint → tunggu >305s → GET lagi	catat AKTUAL (driver lokal mungkin tak menegakkan expiry)	GET @+124s lewat expiry: http_status=000 , curl_exit=28 DNS-fail — TIDAK ada 403 storage; URL expired & hidup tak terbedakan di lokal	N/A-adapted (driver caveat)	pembukian TTL = DEPLOYED (R2 presigned terbukti di T8d: X-Amz-Expires=300)	
POST /api/progress , GET /api/progress	E7 (L17) A tulis own; spoof user_id B di body; GET per user; B tulis lesson milik A	2xx; 400 whitelist; hanya baris sendiri	A POST 201; A POST + user_id:"<B-uuid>" → 400 ["property user_id should not exist"]; A GET → hanya 1 baris milik A; B POST → 403 "Enrollment aktif diperlukan." ; B GET → []; DB: 1 row, user_id=A	PASS	progress ikut entitlement gate, bukan sekadar whitelist; race duplikat = T14C	
PATCH /api/enrollments/:id/revoke	E10 (L18) student revoke sendiri; B revoke A; admin revoke; admin revoke LAGI; /me isolation	non-admin 403; admin 200; ulang → idempotent-atau-4xx (record); me terisolasi	A: 403; B: 403; admin #1: 200; admin #2: 200 + audit revoke nambah 1→2; B /me: []; A /me pasca-revoke: 1 baris status:"revoked"	PASS dengan FINDING	FIND-T9-02: revoke ulang SELALU 200 + audit duplikat (tanpa guard status) — direkam apa adanya	
admin_audit_logs	spot-check (L19) verify/activate/revoke/publish/cancel/create QA actor	baris ada, actor=admin	LIMIT 12 berisi 12 aksi, semuanya actor admin; SELECT mismatch actor = 0	PASS	completeness penuh = T13	
teardown karantina	(L20) course berakhir UNPUBLISHED; order nyasar dibatalkan	draft + konsisten	course draft; lesson draft; orders: 1 paid (fakta historis), 3 cancelled, enrollment revoked; progress 1 baris; proofs 5 baris	PASS	Catatan karantina: users tak bisa dihapus via API → akun qa + proofs + orders historis TINGGAL (jujur)	

Target: DEPLOYED — verdict verbatim: T9-DEPLOYED: 17/20 PASS (incl 3 N/A justified: D13/D16 noKeyAttachment + D19 DBAccess — tanpa satu pun skip diam-diam), FAILs: [], E8-deployed: EXPLOIT-TERBUKTI (paritas penuh lokal; BUG-T9-01 tetap High).

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/orders	E1a (D1) order pertama course published	201, amount server-side	201 9ed781e1... status pending, amount=150000 == price respons POST /courses (klien hanya kirim courseId)	PASS	padanan bukti DB lokal via respons ber-side-server
POST /api/orders	E1b (D2) re-order saat enrollment ACTIVE	amati nyata	201 order baru deed505e... pending	PASS (observasi)	PARITAS deployed [OPEN DECISION] — order dibatalkan di teardown (D20)
payment-proof	E2a (D3) key arbitrator	diterima	201 {message:"Bukti pembayaran berhasil diunggah.",proofId:"48f0d35a..."}	PASS	persis lokal
payment-proof	E8 (D4) traversal ../etc/passwd	amati	201 diterima, proofId 80f6782d...	PASS (probe)	verdict E8-deployed
payment-proof	E8 (D5) encoded traversal	amati	201 diterima, proofId 5e5d940f...	PASS (probe)	
payment-proof	E8 (D6) probe kunci lintas-user B→A	amati; two-sided	B (key sendiri): 201; A submit key MILIK B di order A: 201 3712b0ab...	PASS (probe)	E8-deployed: EXPLOIT-TERBUKTI — raw dua sisi, + key asing private/courses/foreign-alien-* 201
payment-proof	adjacent (D7) B→order A	403	403 "Anda tidak memiliki akses ke order ini."	PASS	guard kepemilikan order ADA; validasi KEY tidak ada (D6)
PATCH /orders/:id/verify	E2b (D8) pending→paid	200 + audit	200 status=paid, respons memuat verifiedAt	PASS (actor audit = N/A-DBAccess)	audit row → D19/T13
verify	E2c (D9) verify cancelled	4xx	400 "Order yang sudah dibatalkan tidak dapat diverifikasi."	PASS	verbatim sama lokal
cancel	E9 (D10) cancel-paid; double-cancel; pending→cancelled	400/400/200	cancel-paid: 400 "Hanya order berstatus pending yang dapat dibatalkan." ; double-cancel: 400 sama; pending→cancelled: 200	PASS	paritas lokal
activate	E3 (D11) activate *2 sekuensial → 1 enrollment	200 + COUNT=1	#1 200 {activatedCoursesCount:1}; #2 200 identik; GET /enrollments/me: tepat 1 baris active	PASS	COUNT via /me (DB deployed non-akses); paralel = T14d
video-url	E4 (D12) tanpa enrollment	403	404 "Video lesson tidak ditemukan." (A pra-aktivasi, B, A pasca-aktivasi — ketiganya identik)	PASS sebagian; cabang 200/403 = N/A-noKeyAttachment	urutan kode: key-null 404 SEBELUM entitlement 403 — gerbang entitlement TIDAK terverifikasi di E4-deployed (jujur)
video-url	E4 (D13) mint + GET url playable	200 {url,expiresAt}	N/A-noKeyAttachment — tak ada jalur API melampirkan key (bukti hidup 400 kedua varian nama field; confirm tanpa bind lesson; tak ada sqlite)	N/A	PROMOSI temuan sistemik (blok di bawah)
video-url	E4c (D14) pasca-revoke	403	404 "Video lesson tidak ditemukan." (identik pra-entitlement)	PASS surface; cabang 403 tak terverifikasi	revoke tak bisa dibedakan dari enrolled pada lesson tanpa key

Endpoint	Skenario	Expected	Actual	Status	Catatan
video-url	E5 (D15) IDOR lintas-user	403/404	404 "Video lesson tidak ditemukan."	PASS (404 aktual; 403-branch tak terverifikasi)	
GET signed URL	E6 (D16) expired >305s	storage menolak (403)	N/A-noKeyAttachment — URL tak pernah bisa diminta (D13) → penegakan TTL 300s R2 tak teruji di baris ini	N/A	justifikasi = temuan terpromosi, BUKAN skip diam-diam; TTL R2 terbukti di T8d read-url
progress	E7 (D17) own + spoof user_id + isolation	2xx/400/own-only	APOST → 201; spoof user_id → 400 ["property user_id should not exist"]; A GET hanya milik A; B POST → 403 "Enrollment aktif diperlukan."; B GET []	PASS penuh	TIDAK bergantung key — teruji penuh deployed (entitlement progress nyata)
revoke	E10 (D18) matrix + /me isolation	403/200/actual[]	A: 403; B: 403; admin #1: 200 status=revoked; admin #2: 200 identik; B /me : [] ; A /me : 1 baris revoked	PASS dengan FINDING	FIND-T9-02 paritas deployed; audit-dup tak terverifikasi → D19
audit	(D19) spot-check actor	actor benar	N/A-DBAccess — tanpa akses SELECT deployed (D1) → pointer T13 (wangler)	N/A-DBAccess	jujur per aturan; bukan FAIL
teardown	(D20) course qa deployed UNPUBLISHED akhir	draft	unpublish 200; publik GET /courses/<slug> → 404; order tersisa cancelled 200*3, 1 tetap paid (historis) — receipt via GET /admin/orders	PASS	Catatan residu: 2+2 akun student qa-t9d, 6 proofs, 4 orders, 1 enrollment revoked TINGGAL (tak terhapuskan via API — jujur)
POST /api/orders	D-EX FIND-T9-06 deployed: order course DRAFT	record actual	201 order d49bca94... pending amount=75000 — order atas course DRAFT DAPAT dibuat (SELECT tanpa filter status)	PASS (observasi)	FIND-T9-06 paritas deployed; dibatalkan di teardown

PROMOSI temuan sistemik (T9d → \$9, High, Open-Parked product-decision): alur video premium TIDAK TERJANGKAU via API pada build ini — tidak ada satu pun rute yang menautkan video_object_key ke lesson (DTO create/update menolak field; confirm tidak bind lesson; deployed tanpa jalur DB tulis) ⇒ GET /lessons/:id/video-url SELALU 404 sebelum cabang entitlement. README "Secure Media & Video Streaming Flow" bersifat FIKSIONAL pada build ini. Perbaikan = surface baru (rute attach key / field DTO) → keputusan pemilik, BUKAN dibuat QA.

\$2.5 Projects/Marketplace/Collective (mapping P1–P6; bukti task-10-portfolio-local.md + task-10-local/raw 63 + task-10-deployed/raw 77)
Target: LOKAL — verdict verbatim: T10-LOCAL: 22/22 PASS, FAILs: []

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/projects	P1-a project DRAFT dibuat (semua field narasi terkirim)	draft → tak muncul publik	HTTP 201, status:"draft", id UUID v4 86bb81fb-...; body = ProjectResponseDto lengkap (problem/solution/techStack/result terisi)	PASS	raw 10
GET /api/projects?q=	P1-b draft qa ABSEN dari katalog publik	draft absent	HTTP 200; items = 0 entri berslug qa-t10-proj-1789279022	PASS	raw 11
GET /api/projects/:slug	P1-c slug DRAFT → 404, bukan datanya	404	HTTP 404 "Project not found." — identik slug tak dikenal (draft#missing)	PASS	raw 12
GET /api/projects/:slug	P1-d slug random → 404 envelope BUKAN 500	404 envelope, no 500	HTTP 404 (bukan 500), envelope keys tepat [statusCode,message,error,timestamp,path]	PASS	raw 13
POST /api/projects/:id/publish → list	P1-e publish → 200 → muncul di list	publish 200 → appears	publish HTTP 200 status:"published" → list ?q= kini total:1, slug hadir	PASS	raw 14,15
GET /api/projects	P1-f list keys	items/page/limit/total/query	keys ACTUAL = [items,page,limit,total]: page:1 limit:100 total:1	PASS	FINDING F-T10-01: query TIDAK di-echo — kontrak repo api-contract.md:98 memang mem-pin 4 kunci TANPA query → teks-task ter-generalisasi dari /courses; bukan bug produk
GET /api/projects/:slug	P2-a detail narasi: problem/solution/techStack/result non-null	field ada + non-null	HTTP 200; summary.problem.solution.result non-null; techStack di-parse jadi ARRAY ["Next.js","NestJS","D1","R2"]; key order respons: ... problem,solution,techStack,result,media,members...	PASS	raw 16,18; urutan RENDER visual = urusan frontend, di luar surface API
POST /api/projects/:id/media → detail	P2-b media attach → array media muncul	media array present	attach HTTP 201; detail: media [{id,mediaType:"image",sortOrder:0}] — objectKey TIDAK terekspos publik (scan 0 hit)	PASS	raw 17,18
POST /api/projects/:id/members	P3-a assign member collective NYATA dengan role	201, built-by role per member	HTTP 201 {projectId,memberId,role:"QA Lead Engineer"}; detail: members: [{memberId,name,role:"QA Lead Engineer"}] — role PER MEMBER terbukti	PASS	raw 20–23,30,31
DELETE /api/projects/:id/members:memberId	P3-b unassign member asli	2xx	HTTP 200 {"message":"Project member removed."}; follow-up detail: members:[]	PASS	raw 35,36; audit 'delete'
POST /api/projects/:id/members (UUID asing)	P3-c assign member ASING → 404	404	HTTP 404 "Collective member not found." — existence check SEBELUM insert (BUKAN FK-500); nol baris terbentuk	PASS	raw 33 (F-T10-04 positif)
DELETE /api/projects/:id/members:asing	P3-d unassign id ASING → 404	404	HTTP 404 "Member assignment not found for this project."	PASS	raw 34
GET /api/collective + /:slug	P4-a member DRAFT: absen list + detail 404	draft absent; 404	create 201 draft; list ?q= 0 entri; detail → HTTP 404 "Collective member tidak ditemukan."	PASS	raw 20–22
POST /api/collective/:id/publish → list	P4-b publish → muncul ONLY after publish	appears only after publish	publish 200 → list ?q= slug hadir (keys [id,name,slug,photo,role,skills,bio,socialLinks,status])	PASS	raw 23,24
GET /api/collective/:slug	P4-c detail TANPA email/phone (recursive scan)	no PII keys	recursive keys VERBATIM: bio,id,name,photo,platform,relatedProjects,role,skills,slug,socialLinks,status; forbidden-key scan [email,phone,password,...] → HITS: []; scan nilai 0 hit	PASS	raw 25; stripping berlapis: DTO + SELECT + mapper
POST/GET /api/marketplace	P5-a create+publish item external_url → detail	externalUri present	create 201 draft; publish 200; detail keys [id,title,slug,description,capabilities,externalUrl,status,media], externalUrl:"https://qa-t10.example.test" verbatim	PASS	raw 40–42; field API = camelCase externalUrl (literal external_url = nama DB)
POST /api/marketplace/:id/pay	P5-b TIDAK ada endpoint pembayaran → 404	404	HTTP 404 — body = HTML fallback Express Cannot POST /api/marketplace/<id>/pay (rute tak terdaftar tak lewat AllExceptionsFilter)	PASS	raw 43; FINDING F-T10-02 (Low) dua kelas 404
POST /api/marketplace/:id/checkout	P5-c endpoint checkout → 404	404	HTTP 404, HTML fallback serupa	PASS	raw 44
POST/DELETE /api/marketplace/:id/media	P5-d media attach/delete per DTO	works per DTO	attach image → 201; mediaType:"screenshot" → 400 ["mediaType hanya menerima nilai image, video, atau deck."]; delete → 200 → media:[]; media item keys [id,objectKey,mediaType,sortOrder] — objectKey EKSPOS publik di marketplace (kontras projects)	PASS	raw 45–48; F-T10-03 asimetri by-design tercatat

Endpoint	Skenario	Expected	Actual	Status	Catatan
Xqlwen Backend Documentation - qa-results.md SEMUA 18 mutation (projects*8, collective*4, marketplace*6) sebagai STUDENT	P6-a student → 403 semua mutation	403	18/18 HTTP 403 "You do not have permission to access this resource."; verifikasi anti-sisi: GET detail setelahnya → tidak ada mutasi boor	PASS	raw 70–87
3 subset mutation TANPA token	P6-b no-token → 401 (distingsi 401≠403)	401	3× HTTP 401 "Missing or invalid authorization token," — berlainan pesan+status dengan 403 student	PASS	raw 90–92: AuthGuard vs RolesGuard terbukti
project detail + collective detail	Relasi dua arah project→member dari KEDUA sisi	both sides	Sisi A: members: [{,role:"QA Lead Engineer"}] . Sisi B: relatedProjects: [{id,title,slug,type,summary,status:"published"}] . TWO-WAY CONFIRMED; negative control pre-assign relatedProjects: []	PASS	raw 31,32 (F-T10-04)
POST :id/unpublish ×3 + GET ×3 + SQL RO	QUARANTINE EXIT: semua qa-t10 DRAFT	unpublish → 404 publik	3×200 status:"draft" ; GET slug → 3×404; DB RO: ketiganya draft, project_members=0, market_media=0, proj_media=1 (row stub pada project DRAFT, tak terekspos publik)	PASS	raw a1–a6

Target: **DEPLOYED** — verdict verbatim: T10–DEPLOYED: 4/8 PASS, FAILS: [P1, P2, P3, RELASI] – keempatnya blocked-by-BUG-T10d-01 (product defect deployed, ber-BUG-id per rubrik)

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/projects (+list/detail)	P1 draft lifecycle (create→absent→404→publish→appears; list keys)	sama	create GAGAL: HTTP 502 cPanel "Bad gateway" HTML, persisten 1×(run-1)×3×(resume @20s backoff)+1×(diag body minimal), latency ~325–400ms → tanpa PROJ_ID, publish/appears tak ter-exercise. Proksi-surface lain terbukti: draft/unknown slug → 404 "Project not found." envelope identik; list keys [items,page,limit,total] TANPA query — parity persis F-T10-01	FAIL (BUG-T10d-01)	raw 04,69–71,001; kandidat orphan draft invisible terdokumentasi (502 mendahului validasi; 409 tak pernah muncul)
GET /api/projects/:slug	P2 narasi 5 field + media array	sama	Tak tercapai: tidak ada proyek milik sendiri (create 502); attach media ke id placeholder → 400 uuid. Guardrail melarang memakai baris milik orang lain	FAIL (blocked-by-BUG-T10d-01)	raw 10,11,12; bukan deviasi perilaku — belum tersentuh
POST/DELETE /api/projects/:id/members	P3 built-by roles + alien 404 ×2	sama	Sisi-proyek tak tercapai (id placeholder → 400 ParseUUIDPipe). Sisi-member TERBUKTI sehat di P4. Alien-assign 404 service-level tak teruji deployed	FAIL (blocked-by-BUG-T10d-01)	raw 19–25; repro siap-jalan begitu create project hidup
GET /api/collective(/:slug)	P4 published-only + PII recursive scan	sama	PARITY PENUH: create 201 draft; list 0 saat draft; detail draft 404; publish → hadir; recursive keys VERBATIM sama lokal; forbidden scan → 0/0 hits	PASS	raw 13–18
POST/GET /api/marketplace(/:slug) + /pay /checkout	P5 externalUri + no-payment 404×2 + media enum	sama	PARITY PENUH: create/publish/detail verbatim; pay & checkout → 404 HTML fallback Express — F-T10-02 TERKONFIRMASI SAMA di deployed; enum 400 verbatim; delete 200 verbatim; objectKey EKSPLOS (F-T10-03 parity)	PASS	raw 26–34; bukti response-surface (no D1)
SEMUA mutation ×student + no-token	P6 403-grouped + 401×≥2	sama	18/18 HTTP 403 verbatim + 3/3 no-token HTTP 401 verbatim; fakta baru: RolesGuard MENDAHULUI ParseUUIDPipe (403 murni guard bahkan dgn id invalid)	PASS	raw 35–55
project detail + collective detail	Relasi dua arah dari kedua sisi	sama	Sisi-B tereksekusi sbg NEGATIVE CONTROL valid: relatedProjects: [] (200). Sisi-A TIDAK teruji — create 502	FAIL (blocked-by-BUG-T10d-01)	raw 20,21; dua-arah TERBUKTI di LOCAL → gap = infra/build deployed, bukan logika
unpublish ×3	QUARANTINE EXIT deployed	sama	Receipts response-surface: member & item unpublish 200 draft → 404 → list absent; proyek: tak pernah published (create 502). Residu terdokumentasi (draft tak publik): 3 collective draft, 1 marketplace draft, 2 students, ±1 project draft orphan — butuh owner D1-cleanup opsional; nol eksposur publik	PASS (adapted-caveat)	raw a1–a9, b-series

BUG-T10d-01 (detail §9): isolasi permukaan — rute lain modul projects SEHAT (publish id asing → 404 JSON service-level), tulis modul lain SEHAT pada detik yang sama (POST /collective → 201), baca GET /projects → 200 ⇒ kegagalan spesifik-rute pada permukaan tulis projects deployed — **satu keluarga dengan BUG-T8d-01** (502-CF family; hipotesis akar utk owner: worker crash mid-route ATAU rule edge/WAF — BUKAN keputusan QA).

§2.6 Admin aggregation (mapping AD1–AD4; bukti task-11-admin-local.md + task-11-local/raw + task-11-deployed/raw 26)

Target: **LOKAL** — verdict verbatim: T11–LOCAL: 23/23 PASS, 1 N/A-adapted (AD1 proof-ref = DL–015 locked), 1 DELEGATED-T13 (completeness), FAILS: []

(hitungan kontrak 23 = 4 AD1 + 3 AD2 + 14 AD3 [diagregasi per-rute 7×2] + 1 AD4 titik + 1 overview; baris AD3 diagregasi di bawah demi format kolom seragam).

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /admin/orders	AD1 top-level keys	{items,page,limit,total}	exactly that	PASS	
GET /admin/orders	AD1 10 mapped kolom (PRD §45 — bukan "Handbook §7")	semua ada per row	10/10 × 6 rows, jq has()=true — [id,user,courseTitles,amount,status,createdAt,updatedAt,activationStatus,grantedBy,grantedAt] ; user = {id,name,email,phone}	PASS	mapping: User/Email/ Course→ c Amount; Or Date→ c r Payment St Activation/C — lihat tabe evidence
GET /admin/orders	WhatsApp/Proof-Reference + "Actions" kolom	dedicated field	ABSENT — 'jq map(select(test("whatsapp\	proof\	action")))
GET /admin/orders?	invalid enum → status=bogus	400	400 ["status hanya menerima nilai pending, paid, atau cancelled."]	PASS	verbatim
GET /admin/users?	AD2 recursive scan	0×password_hash, 0×argon2	jq [paths] → 0 hits: grep argon2 → 0; grep password_hash → 0	PASS	SELECT co (admin.serv
GET /admin/users/id	AD2 same scan (student sendiri)	0/0	0 hits; keys= [createdAt,email,enrollments,id,name,orders,phone,role,status]	PASS	
/admin/users?	AD2 DL-011 bounds	400/400/200-empty	400 "limit maksimal 100." / 400 "page minimal 1." / 200 items=[] page=9999 total=9	PASS	total echo s range page
7 rute /api/admin/*	AD3 guard matrix 7 × (no-token, student) = 14 check	tanpa token → 401 (bukan 403); token user → 403	no-token → 401 verbatim Missing or invalid authorization token. pada SEMUA 7; student → 403 verbatim You do not have permission to access this resource. pada SEMUA 7 — 14/14, tidak ada rute yang collapse	PASS	class-level; admin.contr media.contr per pasang
PATCH /api/courses/id	AD4 audited mutation (SELECT titik)	+1 row, actor=admin uuid	Δ+1 (87→88), row 3f0ee33a, actor= 85cf38c6—6974 == admin uuid; semua 88 rows actor=admin	PASS	completene (delegasi pl sini)

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /admin/media/{upload-url,confirm,read-url}	AD4 audit on media mutations	audited per \$3c intent	ZERO rows + zero call sites (grep audit.record(= 10 call-site map: media = nol)	PASS (re-proof)	→ BUG-T1 (alias BUG-parked, not
(completeness penuh)	AD4 semua aksi QA × actor	—	TIDAK dihitung mid-wave (paralel → non-deterministik); delegated	DELEGATED→T13	hasil T13: 8 admin — ltr
GET /admin/overview	parity vs SELECTs	{userCount,pendingOrders,activeEnrollments}	{"userCount":10,"pendingOrders":1,"activeEnrollments":1} vs SELECT `10` user = {email,id,name,phone}	1\	1' — exact

Target: DEPLOYED — verdict verbatim: T11-DEPLOYED: 21/21 PASS, 1 N/A-adapted (AD1 proof-ref = DL-015, sama lokal), 1 N/A-DBAccess (AD4 → pointer T13; CF token names-only tersedia), FAILs: []

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /admin/orders	AD1 top-level keys	{items,page,limit,total}	exactly that; rows=4, total=4	PASS	DB deployed berisi data lintas pass — STRUKTUR kolom yang diuji, bukan count
GET /admin/orders	AD1 10 mapped kolom	semua ada per row	10/10 × 4 rows, 1 keyset unik [activationStatus,amount,courseTitles,createdAt,grantedAt,grantedBy,id,status,updatedAt,user] ; user = {email,id,name,phone}	PASS	mapping identik lokal
GET /admin/orders	WhatsApp/Proof/Actions kolom	dedicated field	ABSENT — scan keys = []	N/A-adapted	excluded by DL-015 (locked) — sama persis loka
GET /admin/orders?status=bogus	invalid enum	400	400 ["status hanya menerima nilai pending, paid, atau cancelled."]	PASS	verbatim identik lokal
GET /admin/users?limit=100	AD2 recursive scan + pagination	0×password_hash, 0×argon2	paths=0, argon2=0, suspicious keys= [] ; top-keys exact; total=14	PASS	
GET /admin/users/id (student sendiri)	AD2 same scan + shape	0/0	200; keys identik lokal; 0 hash/argon2/suspicious	PASS	
/admin/users bounds (101/0/9999)	AD2 DL-011	400/400/200-empty	400 "limit maksimal 100." / 400 "page minimal 1." / 200 items=[] page=9999 total-echo=14	PASS	parity lokal
7 rute admin × (no-token, student)	AD3 14 check	401 / 403	14/14 — 401 & 403 pesan verbatim identik lokal di semua 7 rute (termasuk 3 media); curl independen spot-check /admin/overview no-token → 401	PASS	tidak ada inkonsistensi
(D1 admin_audit_logs)	AD4 completeness deployed	rows per aksi	TANPA akses D1 dari pass T11d → tidak ada query dieksekusi di sini; token CF names-only HADIR → pointer T13 (wrangler read-only)	N/A-DBAccess	T13 kemudian MENGEKSEKUS 12 SELECT read only (lihat \$3)
API-surface parity AD4	mutation oleh worker ini sendiri	audit per mutasi	Nol aksi-mutasi di pass T11d (read-only; satu-satunya create = akun student karantina via /auth/register, bukan aksi admin) → tidak ada objek audit surface-side	N/A (alasan)	BUG-audit-media tidak di-re-proof deployed di pass ini — milik T13
GET /admin/overview	parity shape	{userCount,pendingOrders,activeEnrollments} sorted-identik	200 keys= [activeEnrollments,pendingOrders,userCount] : values= {userCount:13,pendingOrders:0,activeEnrollments:0}	PASS	values = realitas deployed, tidak dinilai

QUARANTINE EXIT deployed: tidak ada konten dibuat/diubah (satu-satunya artefak = akun student karantina tanpa data); nol mutasi admin dieksekusi.

\$2.7 Home aggregation (mapping H1; bukti task-12-home-local.md + task-12-local/raw + task-12-deployed/raw + artefak t12e-* ; sapuan X1 → \$8)

Target: LOKAL — verdict verbatim: T12-LOCAL: 12/12 PASS, FAILs: [] (H1-b ditutup PASS via T12e Wave-4; hitungan mencakup baris \$8 X1 + teardown receipt)

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /api/home	H1-a No-draft-leak: tokenless saat 4 entitas DRAFT + 1 course PUBLISHED ada	200; slug/nama draft 0 kemunculan di SEMUA array; course published hadir atau dijelaskan cap	200. Scan rekursif: 4/4 slug draft = 0 hits (courses/projects/marketplace/collective). qa-t12-pub-... HADIR di courses[] . Body hanya memuat 2 course (milik sendiri + sibling worker; provenans dicek via detail publik 2/2 = 200, draft akan 404)	PASS	Cap COURSE_LIMIT=4 tidak tercapai → kehadiran published ter-assert langsung, tanpa cabang "cap hides it"
GET /api/home	H1-b Empty-state (DB kosong)	200 bentuk kosong wajar, bukan 500	200 {"courses":[],"projects":[],"marketplace":[],"collective":[]} — keempat array kosong; adjacent GET /api/courses = 200 {"items":[],"page":1,"limit":20,"total":0,"query":null}	PASS (via T12e Wave-4)	Kaveat metode terdokumentasi: premis plan "boot fresh → auto-migrasi" TERBUKTI SALAH — DB tanpa schema membalas 500 sanitised (artefak t12e-literal-*—noSchema.txt , DIARSIP bukan di-pass-kan); empty-state sah = schema valid (migrate via runMigrations bawaan repo, 8/8 file) + nol content. Temuan metode: F-T12e-01 (→ \$9)

Target: DEPLOYED — verdict verbatim: T12-DEPLOYED: 7/7 PASS (H1-b N/A-adapted), FAILs: [], FINDING: BUG-T12d-01 (POST /projects 502 deterministik deployed — infra, CF-class sekelas BUG-T8d-01)

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /api/home	H1-a(d) No-draft-leak via fixture qa-t12d deployed	idem lokal	200. 3 slug draft (course/mkt/col) = 0 hits di SEMUA array; publish → courses[] berisi qa-t12d-pub-... (cap tidak tercapai → terassert langsung); UNPUBLISH → /home **0 string qa-t12d*"; draft publik detail 404	PASS	project-draft TIDAK bisa dibuat deployed: POST /projects → 502 deterministik (CF Bad Gateway HTML, 3× repro) → cakupan draft-project tak ter-exercise langsung; tetap aman by-code (filter status='published' identik home.service.ts:89-91) + array projects tak memuat slug-ku di 3 snapshot. FINDING = BUG-T12d-01 (dedup BUG-T10d-01)
GET /api/home	H1-b(d) Empty-state deployed	—	TIDAK DIUJI — akan butuh menghapus konten published milik orang (course-1 dst.)	N/A-adapted	sesuai plan T12; empty-state = T12e lokal

Temuan pendukung \$2.7 lokal (F-T12-02: collective tidak terindeks FTS; F-T12-03: item /home tanpa field status → provenance via semantic 404) → \$9/\$10.

\$3 Data integrity (T13 — SELECT langsung READ-ONLY; bukti task-13-integrity.md + task-13-raw/)

DB baseline lokal bersih-by-construction (reset T1) → angka global = murni efek Wave 1-4.

Semua sqlite3 memakai file:local.db?mode=ro ; semua wrangler --command "SELECT _" — rows_written:0 / changes:0 di SETIAP envelope D1 (bukti read-only dari respons D1 sendiri).

Adaptasi kolom task-text→aktual (semantik sama): orders amount (bukan total_amount) ;

enrollments granted_at / revoked_at (bukan activated_at).

Basis: LOKAL — T13-LOCAL: PASS (bugs baru: none)

Periksa	Metode (aktual)	Actual (run sungguhan)	Status	Catatan	
Xolvon Backend Documentation - qa-results and (a) dupel enrollment aktif (user_id,course_id)	GROUP BY 1,2 HAVING c>1	0 rows; PRAGMA index_list → UNIQUE autoindex pada (user_id,course_id) TERKONFIRMASI; total enrollments=2 = persis 2 aktivasi ber-evidence (T9 + newman folder-06)	PASS	raw a-enrollments.txt	
(b) order paid ter-activate ↔ enrollment	LEFT JOIN order_id	kedua order paid (22deb73e T9, 5a14f2aa newman) punya enrollment tertaut — 0 yatin; arah invers juga bersih; 1 pending sah (T11)	PASS	raw b-orders.txt ; paid-but-not-activated memang LEGAL per state machine	
(c) admin_audit_logs COMPLETENESS (delegasi T11/AD4)	build expected dari SEMUA capture 2xx admin-mutation wave (classifier call-site) vs GROUP BY action	total 89 baris; AKTOR 89/89 = admin uuid tunggal, non-admin/NULL = 0; expected c actual di SEMUA kategori — tidak ada kategori kurang; delta semua over-capture teratribusi (newman window / siklus same-worker); media = 0 baris by-design (BUG-audit-media parked terkonfirmasi, bukan completeness-miss); double-audit activate×2/revoke×2 = persis prediksi FIND-T9-05/02	PASS	tidak ada BUG-T13 (nol under-capture); raw c-audit.txt, c-attribution.txt	
(d) tidak ada secret di log	grep 'password_hash\	\$argon2\	access token' server.log ×3 = 0 hits; sample-hash 16-char (metode tercatat) grep ke SELURUH evidence tree = 0 hits; regex JWT penuh = 0 file	0 violations	PASS hit kata di transcripts = field-name/label assertion (whitelisted, dikutip berkonteks raw d-secrets.txt)
(e) progress duplikat (baseline PRE-RACE)	GROUP BY user_id, lesson_id HAVING c>1	0 rows dup; total 1 baris → baseline diserahkan ke T14-C	PASS	progress TANPA UNIQUE (0003)	
(f) inventaris residu qa-*	SELECT per label	users 8 qa (total 11), courses qa 8 (semua draft final) + 1 contoh newman, orders 5 qa + 1 newman, proofs 6, enrollments 2 (1 active newman, 1 revoked T9), progress 1, sessions 20, projects/collective/marketplace 2/2/2 semua draft, audit 89 immutable	PASS (inventaris)	karantina-conformant; raw f-residue.txt	

Basis: DEPLOYED (wrangler D1 xolvon-staging --remote , SELECT-only — EKSEKUSI, bukan BLOCKED) — T13-DEPLOYED: PASS

Periksa	Metode (aktual)	Actual (run sungguhan)	Status	Catatan
(a) dupel active	SELECT D1	0 dup; enrollments total=1 (status revoked — enrollment qa-t9d dari D18); changes:0, rows_written:0	PASS	raw dep-a.txt
(b) paid ↔ enrollment	SELECT join	tepat 1 order paid 9ed781e1 → 1 enrollment tertaut (revoked); 3 order lain cancelled; seed data tak tersentuh; 0 yatin	PASS	raw dep-b.txt
(c-lite) audit	SELECT group+join	total 43 baris, aktor TUNGGAL admin-1 (role admin; id legacy non-UUID sesuai T5); spot-map BY NAME seluruhnya ke fixture qa-t7d/t8d/t9d/t10d/t12d; ZERO project-audit-rows deployed = korborasi BUG-T10d-01 (semua POST /projects 502 → tak pernah sampai DB); FIND-T9-02/05 double-audit TERBUKTI DI DB deployed; media entity = 0 rows (paritas kode)	PASS	raw dep-c*,txt ; T5 smoke nol mutasi (dikoreksi via query entitas — tebakan awal penulis dibatalkan)
(d) secret di log deployed	—	N/A — tanpa akses log historis Workers (tail bukan read-only-history); SUBSTITUSI: scan transcript evidence deployed (raw+md) JWT/hash-slice = 0 hit	N/A + substitusi jujur	
(e) progress dup	SELECT	0 dup; 1 baris	PASS	
(f) residu D1	SELECT counts	qa_users 11/15 (4 non-qa = admin + 3 seed pre-QA), qa_courses 8/10 (2 non-qa = seed course-1 + course-2 tgl 2026-09-11, TAK tersentuh QA), proofs 6, sessions 26, progress 1	PASS (inventaris)	

\$4 Concurrency races (T14; bukti task-14-races.md + 10 JSON + task-14-gate-{local,deployed}.txt ; script ter-commit 6209f4e , fix 8397cc9)

Gate keras = invariant DB (SELECT read-only dua basis; semua wrangler rows_written:0),

bukan status HTTP (adjudikasi plan). Window SEPI (pasca T6b/T12e/T13; satu worker).

scripts/qa/race-double-register.mjs + race-double-activate.mjs — Node 22 native fetch,

zero-dependency, kredensial HANYA env, output token ter-redact.

#	Race	Target	Status pair	Gate DB (invariant)	Verdict	Catatan
S1	A: 2× POST /auth/register email sama	LOKAL	[201, 500]	users WHERE email = 1	PASS (1×2xx + 1×non-2xx)	+ BUG-race-500 (Medium): leg non-2xx = 500 sanitised, BUKAN 409 — invariant DB benar, kualitas error gagal
S2	A register paralel	DEPLOYED	[502, 201]	wrangler COUNT = 1 (rw=0)	PASS (pair-shape valid)	leg 502 = CF-class → FIND-T14-02
S3	B: 2× POST /orders/:id/activate paralel	LOKAL	[200, 200]	enrollments(user,course) = 1; course final draft	PASS	upsert UNIQUE idempotent (2×200, 1 baris)
S4	B activate paralel	DEPLOYED	[200, 200]	/enrollments/me activeCount=1 + wrangler enrollments = 1 (rw=0)	PASS	upsert bekerja di D1 juga
S5	C (bonus): 2× POST /progress lesson sama	LOKAL ×2 + DEPLOYED ×2 + seq-control	LOKAL [201,201] ×2; DEPLOYED [201,502-CFhtml] ×2; SEQ [201,201]	rows progress per (user,lesson) = 1 di SEMUA percobaan; dup-pair global = 0 dua target	PASS on invariant; BUG-progress-race TIDAK TERKONFIRMASI	F13 tetap LATENT (constraint tak ada + check-then-insert; deployed race tak teradjudikasi bersih karena writer kedua mati di FIND-T14-02; fix UNIQUE = owner-gated utk D1)

Vonis verbatim: T14: 5/5 PASS (gates: user=1 & enrollment=1 both targets) ; AUTH-RETRY 0 event.

Temuan: **BUG-race-500** (Medium, TIDAK di-fix T16 → Open — §9); **FIND-T14-02** — POST

paralel dari IP sama → 502 HTML Cloudflare pada salah satu leg (reproduktif 2/2 di progress;

sekuensial-control normal) — satu keluarga 502-CF cluster T8d/T10d (→ §9); **FIND-T14-03**

(Low-Med): pre-check register email OR phone padahal users.phone TANPA UNIQUE di DDL →

dobel-insert phone sama secara teori (tidak diuji sebagai race — di luar mandat C4; dicatat);

T14-S: bug derivasi phone di skrip QA sendiri → RED→GREEN commit 8397cc9 (bukan produk).

Cleanup: finally-unpublish tereksekusi dua target (course qa final DRAFT; gate receipts).

\$5 Perf sanity (T15; bukti task-15-perf.md + task-15-local/)

**Query-count per request (LOKAL saja — driver D1 deployed tak bisa diinstrumentasi tanpa

ubah kode; keputusan plan \$decisions).** Instrumen SEMENTARA QA_SQL_LOG=1 di

DatabaseService → capture → git checkout -- src/database/database.service.ts →

git status --porcelain KOSONG (receipt revert-receipt{,-final}.txt) ; server final

clean boot pid 56065, grep -c QA_SQL:: server-t15-clean.log = 0. Patch TIDAK pernah di-commit.

Endpoint	queries limit=1	queries limit=50 (item nyata)	Query lain	Verdict N+1
GET /api/courses	2 (1 item)	2 (13 item — pool dinaikkan ke 13 via API, deviasi premis dicatat)	home = 4 (1/seksi, konstan); video-uri = 2 (lesson + enrollment re-check/request; guard JWT murni stateless tanpa DB — konsisten FINDING window T6)	TIDAK ADA N+1: Δitems +12 vs Δqueries 0 → slope 0 query/item (pola SELECT page + COUNT(*) ; statement SQL terekam counts=*,sqlwindow.txt)

Baseline latency — 20 sample/endpoint/target (curl -w '%{http_code}\t{time_total}';

⌘; pacing.sleep 3; catalog -i 7; signed; 0 sample 429 tereliminasi dua target — 120 samples total):

Endpoint	Target	Status tercap	Median (s)	p95 (s)	Catatan
GET /api/courses	LOCAL	200×20	0.0019	0.0040	min-max 0.0013–0.0065
GET /api/home	LOCAL	200×20	0.0016	0.0021	
GET /api/lessons/:id/video-url	LOCAL	200×20	0.0021	0.0033	key via FIXTURE-METHOD sqlite berlabel (tak ada jalur API — F-T8-04)
GET /api/courses	DEPLOYED	200×20	0.4118	0.8772	RTT edge wajar
GET /api/home	DEPLOYED	200×20	0.3465	0.6101	
GET /api/lessons/:id/video-url	DEPLOYED	404×20	0.4543	0.8245	KAVEAT wajib: mengukur CABANG 404 (key selalu NULL di deployed — tak ada jalur attach; angka = guard+SELECT+404, BUKAN mint presigned penuh). Mini-flow deployed qa-t15d 9/9 2xx via API mumi

T15: N+1=no , latency recorded (local3+deployed3, 0 429-samples excluded). BUG-perf: TIDAK ADA.

FIND-T15-01 (operasi, Low): server anak shell bisa mati senyap saat shell daur-ulang —

mitigasi </dev/null +disown; BUKAN cacat produk. Residu utk T18: qa-t15 **+13 course PUBLISHED

lokal + 1 course published deployed** (exit karantina = mandat T18, belum di-unpublish saat T17).

\$8 Endpoint tambahan di luar matriks (X1–X3 — sapuan 3 kategori, dua target)

X1 — GET /api/search (bukti task-12-home-local.md ; Lokal 9 baris, Deployed 6 baris —

semua PASS; 0×500; tokenless = tanpa guard, terbukti publik):

Target LOKAL:

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /api/search	X1-a happy FTS5 dua arah: token unik pra-publish / published / pasca-unpublish	0 → 1 → 0; draft tidak pernah muncul	pre: 200 total=0 · published: 200 items berisi course qa, 0 draft · post-unpublish: 200 total=0	PASS	Index FTS5 TIDAK stale — trigger 0007 + filter status='published' waktu-query
GET /api/search	X1-b q tak ada hasilnya	200 bentuk kosong	200 {items:[], total:0, query:"zzqq-nonexistent-..."}	PASS	
GET /api/search	X1-c q HILANG total	per DTO verbatim: q @IsOptional() → 200 listing published (teks-task "→400" = SALAH KUTIP, diluruskan §0.6)	200; total=2 items=2 hanya PUBLISHED, 0 draft	PASS (deviasi teks-task didokumentasikan)	F-T12-01
GET /api/search	X1-d q= string kosong	valid per DTO → 200	200 listing sama	PASS	bukan error
GET /api/search	X1-e q 201 karakter	400 verbatim	400 "q maksimal 200 karakter."	PASS	
GET /api/search	X1-f type=bogus	400 enum verbatim	400 "type hanya menerima course, project, atau marketplace."	PASS	
GET /api/search	X1-g tokenless → publik	200 tanpa Authorization	SEMUA 12 panggilan X1 tanpa header Authorization → 200/400 sesuai validasi, tidak pernah 401	PASS	
GET /api/search	X1-h SQL-injection q="'; DROP TABLE users;—"	200/400 aman (bukan 500)	200 total=0; toFtsQuery mensterikan → DROP* AND TABLE* AND users*; query di-echo sbg string	PASS	regress /courses + /home 200 setelahnya — DB utuh
GET /api/search	X1-i unicode q=kérs 日本語 tect	200 aman	200, query ter-echo utuh, total=0	PASS	

Target DEPLOYED:

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /api/search	X1-a(d) FTS5 dua arah deployed	idem lokal	published: q=token → 200 total=1 item course-ku; pasca-unpublish → 200 total=0; 0 draft di kedua titik	PASS	FTS5 BERFUNGSI di D1 deployed (F-T12-04) — bukan index staleness
GET /api/search	X1-b(d) q tak ada hasil	200 kosong	200 {items:[], total:0, query:"zz-tidak-ada-..."}	PASS	
GET /api/search	X1-c(d) q hilang total	200 listing published (per DTO; teks-task 400 = salah kutip)	200 total=4 items=4, query:""; 0 draft bocor	PASS	F-T12-01 ter-reproduksi deployed
GET /api/search	X1-e(d) q 201 karakter	400 verbatim	400 "q maksimal 200 karakter."	PASS	
GET /api/search	X1-h(d) injection SQLi	200/400 aman	200 total=0 tematuralisasi; regress /courses + /home 200 → DB utuh	PASS	
GET /api/search	X1-g(d) tokenless	200 tanpa Authorization	SEMUA panggilan X1 tanpa Authorization → 200/400, tidak pernah 401/403	PASS	X1-f(d) type=bogus tidak diulang deployed (hemat budget catalog 30/menit shared — tercatat)

X2 — POST /api/lessons/:lessonId/resources + DELETE /api/resources/:id — baris lengkap

ADA di §2.3 (penempatan fisik mengikuti artefak task-8). Ringkasan 3 kategori dua target:

Endpoint	Skenario	Expected	Actual	Status	Catatan
POST /api/lessons/:id/resources	valid (admin) — LOKAL	create valid	HTTP 201; DB row object_key = key server-generated persist penuh	PASS	§2.3 LOKAL X2a
POST /api/lessons/:id/resources	student / field invalid / lesson asing — LOKAL	403 / 400 / 404	403 "You do not have permission..." ; 400 enum type verbatim; 400 7 pesan {} ; 404 "Lesson tidak ditemukan."	PASS	§2.3 LOKAL X2b–X2e4
DELETE /api/resources/:id	admin delete / id asing — LOKAL	2xx+gone / 404	200 + SELECT COUNT=0; re-DELETE & random-UUID → 404 "Resource tidak ditemukan."	PASS	§2.3 LOKAL X2d/X2e
POST /api/lessons/:id/resources	valid (admin) — DEPLOYED	201	HTTP 502 deterministik 5/5 — halaman edge Cloudflare, BUKAN envelope app	FAIL (BUG-T8d-01)	§2.3 DEPLOYED X2a; guard 403/pipe 400/read 404 sehat → kegagalan spesifik jalur INSERT deployed
POST /api/lessons/:id/resources	student / field invalid — DEPLOYED	403 / 400	403 verbatim; 400 "type hanya boleh salah satu dari: pdf, resource, assignment." ; 400 7 pesan	PASS	lapisan guard/pipe sehat deployed
DELETE /api/resources/:id	happy + error — DEPLOYED	2xx+gone / 404	happy-path TIDAK tercapai (diblokir BUG-T8d-01); error legs TERBUKTI: non-UUID → 400 "Validation failed (uuid v4 is expected)" ; random UUID → 404 "Resource tidak ditemukan."	FAIL (blocked-by-BUG-T8d-01)	§2.3 DEPLOYED

X3 — GET /api/auth/admin — baris lengkap ADA di §2.1 (L18 lokal / seq22–24 deployed):

Endpoint	Skenario	Expected	Actual	Status	Catatan
GET /api/auth/admin	3 kategori — LOKAL	401/403/200	401 Missing or invalid authorization token. / 403 You do not have permission... / 200 {"message":"Admin access granted","...}	PASS	§2.1 LOKAL baris X3
GET /api/auth/admin	3 kategori — DEPLOYED	401/403/200	401 (seq22) / 403 (seq23) / 200 Admin access granted. (seq24 — sub admin-1)	PASS	§2.1 DEPLOYED + pre-check T5 §3

§9 BUG REGISTER

Format: ID	severity	status	repro	retest/bukti	Semua pasangan T16 = commit
------------	----------	--------	-------	--------------	-----------------------------

test(...) → fix(...) dengan bukti RED/GREEN/SURFACE per bug (files task-16-bug-B*→*.txt).

ID	Severity	Status	Repro	Retest / bukti
BUG-T9-01 (payment-proof objectKey arbitrér — dulu BUG-payment-objectKey)	High	FIXED (LOKAL) — 722f45d→90758d8 (validasi prefix MEDIA_PREFIXES + tolak traversal) · PENDING-REDEPLOY (DEPLOYED) — build deployed masih PRE-FIX · residual Open-Parked (owner): lintas-user sesama key DALAM prefix sah masih diterima (butuh endpoint upload mahasiswa = surface baru)	§2.4 L3-L7 / D3-D7 (t9 raw; node t9d	task-16-bug-B1-red.txt (201 arbitrer) → ...-green.txt → ...-surface.txt LIVE :3005: traversal/encoded/double-encoded/backslash/foreign-prefix/absolute → 400; key sah prefixs → 201 dipinned; order-ownership 403 tak berubah
BUG-audit-media (alias BUG-T11-01-candidate)	High (audit gap)	FIXED (LOKAL) — e50bcb8→5cc25e6 (AuditService.record di upload-url & confirm: read-url TIDAK di-audit — di luar scope, dicatat) · PENDING-REDEPLOY deployed	§2.6 LOKAL baris media 0 rows; raw/ad4-sqlite-transcript.json	task-16-bug-B3-{red,green,surface}.txt : rows muncul dengan actor admin benar
BUG-throttle-refresh-logout (refresh/logout hanya 100/menit global)	Medium	FIXED (LOKAL) — 317f8c6→dc798b2 (@Throttle 5/min per-handler) + unit test; catatan: e2e lama yang MENGODIFIKASI bug ("without @Throttle") diganti assertion 5/min — justifikasi di test · PENDING-REDEPLOY deployed (bukti permukaan deployed: x-ratelimit-limit: 100)	task-6b \$DEPLOYED probe (t6bd-probe.txt)	task-16-bug-B2-{red,green,surface}.txt : live :3005 x-ratelimit-limit: 5, 429@call-6 di refresh & logout
BUG-seed-driver (seed:admin menembak D1 REMOTE saat .env DB_DRIVER=d1)	High (Critical utk QA containment)	FIXED — 852f829→4c7d628 (preflight menolai driver # sqlite kecuali ADMIN_BOOTSTRAP_ALLOW_REMOTE=1) + unit + surface refusal dibuktikan · PENDING-REDEPLOY tak relevan (perintah lokal; deployed tak menjalankan seed)	task-1-preflight.txt \$ROOT CAUSE (stack D1Service; INSERT gagal 502, nol data remote berubah)	task-16-bug-B4-{red,green,surface}.txt : refusal eksplisit utk d1; happy path sqlite intact
BUG-seed-opaque (catch() => {}) menelan pesan error seed)	Low	FIXED — 354dee8→dd9f337 (log err.message tanpa secret)	seed-admin.log run-1: "Check controlled command configuration." tanpa detail	task-16-bug-B5-{red,green,surface}.txt
BUG-race-500 (register paralel → 500 sanitised, bukan 409)	Medium	OPEN — TIDAK masuk pasangan fix T16 (fakta dari task-16-bugs.md : 5 bug lain saja; tidak dikarang)	§4 S1 [201,500] task-14-race-reg-local.json ; akar: pre-check kalah oleh UNIQUE; constraint SQLite tak di-map → 409	retest bila diff: race A lokal harus [201,409] + users=1
BUG-T4-14/15 (confirm & read-url media → 201 vs kontrak tak ter-pin)	Medium	OPEN-PARKED — adjudikasi: dokumentasikan 201 di api-contract ATAU @HttpCode(200) di controller = keputusan produk (F-T8-07 keluarga sama)	task-4-newman-local.txt #26/#27; §2.3 LOKAL M2a/M2d	collection newman lain tetap gagal di 27 assertion → lihat klasifikasi §L1
BUG-T8-01 (confirm tidak memvalidasi eksistensi objek — tanpa HEAD-check)	Low-Med	OPEN-PARKED — fix = HEAD-object check = perubahan perilaku; kontrol dua sisi (key nyata vs fabricated, sama-sama 201) terbukti DI ATAS R2 NYATA	§2.3 DEPLOYED baris M2c (raw 13 vs 14)	keputusan owner
BUG-T8d-01 / BUG-T10d-01 / BUG-T12d-01 / FIND-T14-02 (keluarga 502 POST deployed)	High (DEPLOYED availability)	OPEN — infra/deploy-side, di luar kode QA-scope. T10d-01 = konfirmasi independen T12d-01 (dedup). §2.5 deployed P1/P2/P3/RELASI FAIL karena ini; deterministik lintas-waktu & payload; server: CF, body HTML bukannya envelope	repro §2.3 §2.5/§4 rows; raw task-8-deployed 32-35, task-10-deployed 69-71+d01, raw-probe T12d, task-14-race-*.json	Owner action: redeploy build pasca-fix + cek rule edge/WAF/worker (timeout subrequest D1), lalu re-run driver T10d/T8d (siap-jalan, TS baru otomatis)
BUG-T6-window (logout tidak mendenyist access JWT — jendela ≤15 mnt)	Medium	OPEN-PARKED (owner) — denylist = surface baru, dilarang plan; PARITAS DUA TARGET	§2.1 A5 kedua tabel (seq19–21 deployed)	owner decision
[OPEN DECISION] checkout policy — E1b order ganda saat enrollment ACTIVE = 201 + FIND-T9-06 order atas course DRAFT = 201 (SELECT tanpa filter status) + F-T9d-01/TIDAK-ADA-API attach video_object_key (alur video premium terputus; README flow §3 fiksional di build ini)	High	OPEN-PARKED (owner) — ketiganya butuh keputusan/feature baru di luar wewenang QA; tidak ada aturan bisnis yang di-invent	§2.4 L2/D2, D-EX, PROMOSI block; F-T8-04	vonis terblokir oleh ini sampai owner adjudikasi
F-T8-02 metadata media tidak dipersist ("register object metadata")	doc-drift (bukan bug runtime)	DOCUMENTED — T16 B3 menambah audit trail upload/confirm, TAPI tabel metadata tetap tidak ada; janji README belum ditepati	§2.3 LOKAL baris DB-metadata + DEPLOYED M2c paritas	→ §10
FIND-T9-02 / FIND-T9-05 (double-revoke & double-activate → 200 + audit dup + count misreport)	Low-Med (latent, audit noise)	DOCUMENTED — latent, dua target + TERBUKTI DI DB D1 deployed (T13); keputusan idempoten-vs-400 milik owner	§2.4 L11/L18, D11/D18; task-13(c)	—
F-T12e-01 boot tanpa auto-migrate pada DB fresh → 500 sanitised "no such table"	Low (ops/dokumentasi)	DOCUMENTED — handover docs/README.md §2.4 sudah BENAR (server tidak auto-migrate); premis PLAN yang salah — diverifikasi & dikoreksi jujur saat T12e	artefak t12e-literal-*-noSchema.txt	rekomendasi owner: migrate-on-boot eksplisit ATAU freeze prasyarat seed/migrate
F-T10-01..04 (list keys tanpa query : dua kelas 404 JSON-vs-HTML; asimetri objectKey marketplace; alien-assign 404 bersih)	Low/doc-parity	DOCUMENTED — paritas dua target terkonfirmasi (F-T10d-01/02/03)	§2.5 rows + FINDINGS	jangan tambah key (guardrail)
FIND-T14-03 (pre-check email OR phone tanpa UNIQUE di users.phone)	Low-Med	DOCUMENTED — latent (tidak diuji sebagai race; di luar mandat C4)	§4 temuan	owner bila mau constraint
BUG-progress-race	—	TIDAK TERKONFIRMASI — F13 LATENT (invariant tak pernah patah di permukaan yang diuji; constraint tetap absen secara kode; fix UNIQUE owner-gated utk D1)	§4 S5	—

Catatan severity T16: semua fix terverifikasi suite penuh pasca-T16 — test:esm 425/425 (46 suites),

test:e2e 109/109, build exit 0, lint 1 warning pre-existing (bukan dari T16) — task-16-final-suites.txt.

§10 Doc-drift (DICATAT — TIDAK diperbaiki, sesuai guardrail plan)

1. Tests-38 Suites	: 335 Passing + komentar "Run complete unit test suite (38 suites, 335 tests)" = basi. Fakta terukur: saat T3 = 44 suites / 411 tests + e2e 107; pasca-fix T16 = 46 suites / 425 tests + e2e 109. (Handover docs/README.md §4 menulis 44/411+107 — kini juga bergeser ke 425/109.)
--------------------	--

2. Klaim auth flow README: "Session tracking... continuous session rotation" + flow cookie tidak menggambarkan implementasi Bearer-only (DL terkunci); refresh me-mint access baru TANPA rotasi refresh token; ERD kolom sessions.token_hash aktual bernama refresh_token.

3. is_preview + diagram §3 "Secure Media & Video Streaming Flow": kolom tidak ada di DDL, branch tidak ada di service, video_object_key tak bisa dilampirkan via API → flow 200/403 presigned fiksional pada build ini (TERBUKTI, F-T8-05 + PROMOSI T9d) — masuk §9 sebagai OPEN DECISION High.

4. Janji "register object metadata" di POST /admin/media/confirm (README endpoint matrix) — tidak ada label/penulisan metadata sama sekali (F-T8-02).

5. Path Postman: README §10 menunjuk xolvon-API.postman_collection.json di root (file tsb sudah dihapus/DL-026) — aktual postman/xolvon-backend.postman_collection.json + postman/environments/(baseUri :3000).

6. **ERD/kolom lain:** `README` `admin_audit_logs.admin_id` aktual `actor_user_id`; `orders.total_amount` aktual `amount`; `enrollments.activated_at` aktual `granted_at / revoked_at`; body respons video-url aktual `{url, expiresAt}` tidak terdokumentasi di mana pun (`FIND-T9-03`);
Xolvon Backend Documentation - qa-results.md

7. **Teks-tas/matriks sumber** (bukan repo, diluruskan di \$0): "Handbook §7/§12" → `PRD §45/§2`; `POST /admin/courses` → `POST /api/courses`; X1 "q hilang → 400" salah kutip (DTO `@IsOptional` → 200); assertion cookie-flags → N/A Bearer-only.

RINGKASAN & VONIS

Yang hijau (fakta, bukan opini):

- \$2.1–\$2.7 LOKAL: **0 FAIL produk di seluruh matriks** (satu-satunya N/A = cookie, stub-driver, path-divergence — semua beralasan). DEPLOYED: 0 FAIL produk KECAULI 4 baris \$2.5 + 2 baris \$2.3 (X2) yang semuanya satu akar keluarga **502-CF deployed**.
- E-group: lokal 19/20+1 N/A, deployed 17/20+3 N/A justified, **FAILs: []** dua target; E8 punya verdict EXPLOIT-TERBUKTI dua target dan sudah diFIX di LOKAL (B1).
- §3 integrity: **bersih dua basis** (0 dup, 0 yatim, audit 89/89 actor benar lokal + 43 baris single-actor deployed, 0 secret). §4 races: **5/5 PASS** (invariant user=1 & enrollment=1 dua target). §5: **N+1 TIDAK ADA**, latency waras.
- 5 bug (B1–B5) di-fix test-first dengan pasangan commit + bukti RED/GREEN/SURFACE; suite kini 425 unit + 109 e2e hijau.
- Karantina dipatuhi: nol baris non-qa diubah; exit karantina terverifikasi per task; deployed admin data tak tersentuh.

Rubrik vonis (plan §Verification strategy): "Siap production" ⇔ seluruh E-group PASS **DAN** §3 & §4 bersih/ter-fix **DAN** nol Critical/High Open — **dengan catatan eksplisit: Open-Parked dihitung sebagai blocker**.

Daftar blocker (hitung jujur dari §9):

- Build deployed masih PRE-FIX** — B1 (High security) ... B5 belum terbukti di target production; butuh redeploy (owner/infra).
- Keluarga 502-POST deployed** — BUG-T8d-01, BUG-T10d-01(=T12d-01), FIND-T14-02 (High availability, OPEN; 4 baris \$2.5 FAIL deployed; infra-side).
- [OPEN DECISION] High:** tidak ada jalur API menautkan video ke lesson → alur premium terputus (F-T9d-01 promoted) — surface baru = owner.
- [OPEN DECISION] High:** checkout policy (E1b order ganda + FIND-T9-06 order course draft) — owner.
- BUG-T9-01 residual** Open-Parked (lintas-user sesama prefiks) — butuh endpoint upload mahasiswa = owner.
- BUG-T6-window** Medium Open-Parked (denylist) — owner.
- BUG-T4-14/15** Medium OPEN-PARKED (kontrak 201-vs-200) — keputusan produk.
- BUG-T8-01** Low-Med Open-Parked (HEAD-check) — owner.
- BUG-race-500** Medium OPEN (tidak di-fix T16) — kandidat catch constraint→409.

→ **VONIS: BELUM SIAP PRODUCTION**. Bukan karena matriks lokal gagal — lokal justru

0 FAIL dan §3/§4/§5 bersih — tapi karena (a) parity deployed belum terbukti (build pre-fix + 502-CF family masih OPEN High), dan (b) tujuh item Open-Parked/Open (3 di antaranya High)

secara eksplisit dihitung blocker oleh rubrik. Jalan tersingkat ke "Siap":

1) redeploy build pasca-fix → re-run driver deployed (T6d–T12d siap-jalan); 2) owner adjudikasi

video-attach + checkout + denylist + T4-14/15 + T8-01; 3) fix BUG-race-500; 4) unblock &

verifikasi keluarga 502-CF (akses worker log/edge rule).

Sampai saat itu, status bagian T20 di atas (BLOCKED untuk klaim production) TETAP berlaku —

addendum ini menutup kesenjangan verifikasi dua-target, bukan menutup gerbang production.

Checklist DoD §7 (addendum ini — tiap kotak dengan pointer bukti)

- [x] 1. **L1 dua target, count tercatat** → \$L1: `task-3-l1.md` (44/411+107/107 → pasca-fix 425/109 `task-16-final-suites.txt`), `task-4-newman-local.txt` (75 req/150 assert/27 fail terklasifikasi; 0 throttle), `task-5-newman-smoke.txt` (9/9+18/18).
- [x] 2. **Matriks §2.1–§2.7 terisi dua target, kolom addendum literal, Actual dari run sungguhan** → §2.1–§2.7 di atas + `task-6..task-12-*..md` + direktori `raw/` masing-masing: tidak ada sel Actual kosong; status di luar (PASS,FAIL) selalu berlabel (N/A-adapted/N/A-DBAccess/N/A-noKeyAttachment/ENV-THROTTLE/DELEGATED) dengan alasan.
- [x] 3. **§3 integrity SELECT langsung dua basis + read-only terbukti** → §3: `task-13-integrity.md`, `task-13-raw/` (wrangler `rows_written:0` di semua envelope).
- [x] 4. **§4 races, skrip ter-commit, verdict binari** → §4: `scripts/qa/*..mjs` (6209f4e, fix 8397cc9), `task-14-races.md` 5/5 PASS.
- [x] 5. **§5 perf: query-count + latency, instrumen direvert bersih** → §5: `task-15-perf.md` (porcelain kosong, `QA_SQL_LOG` grep 0, server final pid 56065).
- [x] 6. **Bug workflow: repro→severity→fix test-first→retest; Critical/High tidak tersisa Open TANPA tercatat sebagai blocker vonis** → §9 + `task-16-bugs.md` (5 pasangan commit; semua Open-Parked/High yang tersisa TERDAFTAR sebagai blocker vonis di atas — tidak ada yang hilang diam-diam).
- [x] 7. **§6 output: docs/qa-results.md append bagian bertanggal + vonis eksplisit** → addendum ini; `docs/pdf/qa-results.pdf` = tugas T18 berikutnya (di luar lingkup commit T17).
- [x] 8. **§0 pemetaan deviasi metode/path tercatat, bukan ditutupi** → §0 butir 1–11 (port, DB_DRIVER override + insiden, Bearer, path-divergence, PRD §45/§52 + salah kutip, newman flags, node-fetch, reset DB, fingerprint, karantina, cross-lane review sha `8b47f4f1..` + folded corrections).

§Resolusi-C — Cleanup residu QA di D1 staging (2026-09-13)

Eksekusi Bagian C addendum blocker-resolution: penghapusan residu QA/smoke dari D1 `xolvon-staging` (remote) dengan disiplin **backup-dulu-then-delete**, SELECT-only untuk inventarisasi, tanpa menyentuh Workers/R2.

Pola residu yang didefinisikan dari bukti (§Residu §2.5 T10d, `task-13-raw/dep-c*.txt`, `task-18-teardown.md`, §5 T15): user email LIKE 'qa-@example.test' OR 'smoke-@example.com'; konten slug LIKE 'qa-@' (`courses/collective/marketplace`) atau dependent-by-FK ke orang/konten tsb (lessons, orders, order_items, payment_proofs, enrollments, progress, sessions, admin_audit_logs). Semua baris terhapus ber-tanggal 2026-09-13 dalam jendela sesi QA.

Backup pre-cleanup (SELECT penuh sebelum DELETE apa pun): `.omo/evidence/xolvon-qa-endpoint-testing/resolusi/pre-cleanup/*.json` — 20 file: users (18 baris; kolom `password_hash` sengaja TIDAK di-dump — keamanan); sisanya penuh; sessions (40), courses (12), lessons (10), orders (6), order_items (6), payment_proofs (6), enrollments (3), progress (4), collective_members (5), marketplace_items (3), projects (1), `course_tags/course_resources/project_tags/project_medialproject_members/marketplace_media` (0), `admin_audit_logs` (60), `schema_ddl.json` (DDL live dari `sqlite_master`). Plan dry-run tereksekusi di SQLite in-memory memakai DDL live + trigger FTS asli + `PRAGMA foreign_keys=ON: PASS` (`resolusi/dry-run-counts.txt`).

Yang dihapus (table × jumlah): progress 4 · course_resources 0 · course_tags 0 · admin_audit_logs 60 · sessions 15 · order_items 6 · payment_proofs 6 · enrollments 3 · orders 6 · lessons 8 · courses 10 · collective_members 3 · marketplace_media 0 · marketplace_items 2 · users 15 = **141 baris, 15 langkah anak→induk** (receipt per langkah: `resolusi/cleanup-execution/del-<table>.json`). Catatan metering: `meta.changes` D1 menghitung operasi trigger (courses: 40 utk 10 baris; marketplace_items: 8 utk 2 baris) — kebenaran diverifikasi via SELECT ulang, bukan `changes`. FTS (external-content + AFTER DELETE trigger 0007) auto-sync: `course_fts=2`, `project_fts=1`, `marketplace_fts=1` — tidak ada entri qa tersisa.

Keputusan audit: audit bersifat append-only, TAPI seluruh 60 baris staging terbukti milik aksi atas konten qa (58 via keanggotaan `entity_id` ke baris qa yang terhapus; 2 baris `marketplace_media` create/delete via tautan `metadata.marketplaceItemId = 28ed60d2..` = item qa-t10d — baris media-nya sudah dihapus QA sendiri saat runtime). Maka 60-60 dihapus; **0 baris audit non-QA dikorbankan** (memang tidak ada). `admin_audit_logs` staging kini kosong = nol noise yatin.

Yang DIKEEP (borderline/pola-tidak-cocok — safety rule "ragu → keep"):

- `f2d5a258.. xolvon@example.com` (dibuat 2026-09-13T02:36Z, SEBELUM jendela QA 05:11Z dan TIDAK cocok pola qa-(smoke)- + 1 session-nya → KEEP).
- 24 session `admin-1` (login admin selama QA — milik user terlindungi, bukan residu by-pattern) → KEEP.
- Seed pre-QA (created_at 2026-09-11): `admin-1/admin@xolvon.com`, `user-1/user@test.com`, course-1 (ai-whatsapp-automation) + course-2 (web-coding-dasar), lesson-1/lesson-2, project-1 (CafeMargin), member-1 (Farsya), member-2 (Budi), marketplace-1 (LeadHunter) → KEEP. Catatan: "project-contoh/produk-contoh/nama-anggota" tidak ada di staging; padanan live-nya adalah baris seed di atas. "1 project draft orphan T10d" terbukti LOKAL saja — projects deployed hanya project-1 → 0 delete.
- Tidak ada baris qa-yang-tidak-tercaptur-pola yang dihapus diam-diam; cross-check dry-run: 0 lesson ber-judul qa di luar course qa; 0 project cocok pola.

Verifikasi (post-delete, `cleanup-execution/final-verify.json`): semua count per-pola = 0 (users, courses, lessons, orders, enrollments, progress, sessions, collective, marketplace, projects, audit total, proofs total) · terlindungi utuh: users=3, course-1/2=2, lesson-1/2=2, members=2, marketplace-1=1, project-1=1, admin-sessions=24 · surface publik via node fetch: `GET /api/courses` 200 (hanya course-1), `GET /api/courses/ai-whatsapp-automation` 200, `GET /api/home` 200 (payload seed-only) — receipt `cleanup-execution/surface-probes.txt`.

Temuan sampling (dicatat, tidak diperbaiki di sini): skema D1 staging SUDAH BEREVOLUSI dari `src/database/migrations/*.sql` repo (CASCADE lebih luas di sessions/progress/enrollments/course_tags/course_resources; `courses.preview_video_key`; `lessons.is_preview`; `course_resources` tanpa `course_id`) — drift repo-vs-deployed untuk owner. Residual R2 (1 objek 70 B penanda QA, tanpa endpoint delete objek) TETAP ada by design — di luar lingkup C (D1 only).

Vonis: P2-C: RESIDU-BERSIH — 141 baris terhapus pola-terverifikasi, 0 residue count post-check, terlindungi utuh, publik 200; backup 20 file + dry-run PASS terekam.

\$Resolusi-Final — Resolusi Blocker & Re-verifikasi Deployed (2026-09-14)

Eksekusi addendum prompt resolusi blocker dan re-verifikasi lingkungan target deployed (https://xolvon.canadev.my.id/api).

1. Bagian A — Resolusi 3 Endpoint 502 Deployed (Root Cause & Bukti)

1. POST /projects (admin)

- **Root cause:** Skema D1 staging memiliki kolom projects.type TEXT NOT NULL CHECK (type IN ('project', 'saas', 'research', 'design', 'other')). DTO CreateProjectDto memiliki type opsional. Ketika client tidak mengirimkan type, database D1 menolak dengan constraint violation yang menyebabkan unhandled exception 502 di edge Cloudflare.
- **Fix:** Update src/projects/projects.service.ts agar mengisi default dto.type ?? 'project' (DL-033).
- **Bukti Deployed:** POST /projects dengan token admin mengembalikan 201 Created (id UUID ter-generate, row tersimpan).

2. POST /lessons/:id/resources (admin)

- **Root cause:** Schema drift pada D1 staging xolvon-staging. Tabel course_resources di staging dibuat dari migrasi lama yang belum memiliki kolom course_id, sedangkan kode aplikasi melakukan INSERT INTO course_resources (... , course_id). Ini memicu SQL error fatal 502 di edge Cloudflare.
- **Fix:** Dijalankan ALTER TABLE course_resources ADD COLUMN course_id TEXT REFERENCES courses(id); pada database remote xolvon-staging sesuai approval owner (DL-034).
- **Bukti Deployed:** POST /lessons/:lessonId/resources dengan payload { type: "pdf", objectKey: "...", title: "..." } mengembalikan 201 Created.

3. Concurrent race (race-double-register.mjs)

- **Root cause:** Balapan dua registrasi simultan dengan email yang sama memicu UNIQUE constraint error di D1 yang tidak tertangkap oleh service layer, menghasilkan status 502/500 pada request kedua.
- **Fix:** Pemetaan UNIQUE constraint violation di src/database/d1.service.ts dan src/auth/auth.service.ts menjadi ConflictException (409) terstruktur.
- **Bukti Deployed:** Eksekusi node scripts/qa/race-double-register.mjs --base-url https://xolvon.canadev.my.id/api menghasilkan:

statusCodes: [409, 201], successCount: 1, nonSuccessCount: 1, verdict: PASS. Tepat 1 user terbuat di database.

2. Bagian B — Implementasi 5 Product Decisions

1. B.1 Attach Lesson Video

- **Implementasi:** Dibuat endpoint PATCH /api/admin/lessons/:id/video (dan alias /api/lessons/:id/video) khusus role admin. Menerima body { objectKey: string }.
- **Validasi:** objectKey wajib terdaftar di media_objects (sudah melalui confirm-upload) dan wajib berada di prefix private/courses/{course-id}/lessons/{lesson-id}/video/.
- **Audit:** Mencatat audit log action attach_lesson_video di admin_audit_logs.
- **Bukti Deployed:**
 - Positif: Attach key confirmed & valid prefix mengembalikan 200 OK (videoObjectKey ter-update).
 - Negatif 1: Attach key dengan prefix lesson/course lain mengembalikan 403 Forbidden.
 - Negatif 2: Attach key yang belum di-confirm (ghost) mengembalikan 400 Bad Request.

2. B.2 Checkout Policy (Draft & Double Order)

- **Implementasi:** Di src/orders/orders.service.ts, validasi checkout POST /orders:
- **Validasi:** objectKey wajib terdaftar di media_objects (sudah melalui confirm-upload) dan wajib berada di prefix private/courses/{course-id}/lessons/{lesson-id}/video/.
- **Audit:** Mencatat audit log action attach_lesson_video di admin_audit_logs.
- **Bukti Deployed:**
 - Positif: Attach key confirmed & valid prefix mengembalikan 200 OK (videoObjectKey ter-update).
 - Negatif 1: Attach key dengan prefix lesson/course lain mengembalikan 403 Forbidden.
 - Negatif 2: Attach key yang belum di-confirm (ghost) mengembalikan 400 Bad Request.

3. B.3 Residual Cross-User Proof Key

- **Implementasi:** Presigned proof URL di-scope ketat ke private/users/{user_id}/proofs/{uuid}.{ext}. Endpoint POST /orders/:id/payment-proof-url dan POST /orders/:id/payment-proof memvalidasi kepemilikan order dan kesesuaian prefix dengan user session.
- **Bukti Deployed (Live Exploitation Test):**
 - User A mint proof URL -> URL dan key diterbitkan dengan prefix private/users/{userA.id}/proofs/... (201 Created).
 - User B mencoba mint URL untuk order User A -> 403 Forbidden (PASS).
 - User B mencoba submit objectKey milik User A untuk order User B -> 403 Forbidden (PASS).
 - User A submit objectKey miliknya sendiri -> 201 Created (PASS).

4. B.4 Stateless JWT Logout Window <= 15 Menit

- **Keputusan:** Sesuai keputusan produk V1, arsitektur auth tetap stateless JWT tanpa distributed blocklist (DL-036). Jendela validitas token pasca-logout maksimal 15 menit diterima sebagai Known Limitation.
- **Dokumentasi:** Dicatat eksplisit di docs/security.md (\$Known Limitations #6) dan docs/decision-log.md (DL-036).

5. B.5 Kontrak 201 vs 200 REST Contract

- **Implementasi:** Di src/media/media.controller.ts:
- @Post('confirm') secara eksplisit @HttpCode(HttpStatus.CREATED) (201 Created) karena mencatat metadata media baru.
- @Post('read-url') secara eksplisit @HttpCode(HttpStatus.OK) (200 OK) karena hanya me-mint signed URL sementara tanpa membuat resource baru.
- **Bukti Deployed:**
 - POST /admin/media/confirm -> 201 Created (PASS).
 - POST /admin/media/read-url -> 200 OK (PASS).

3. Bagian D — Re-verifikasi Deployed & Paritas Target

1. Hasil Eksekusi Re-verifikasi Deployed (13/13 PASS):

Artefak tersimpan di .omo/evidence/xolvon-qa-endpoint-testing/resolusi/deployed-reverification-receipts.json:

- [A.1] POST /projects (admin) -> 201 Created (PASS)
- [A.2] POST /lessons/:id/resources (admin) -> 201 Created (PASS)
- [B.5-a] POST /admin/media/confirm -> 201 Created (PASS)
- [B.5-b] POST /admin/media/read-url -> 200 OK (PASS)
- [B.1-pos] PATCH /admin/lessons/:id/video (valid attach) -> 200 OK (PASS)
- [B.1-neg-prefix] PATCH /admin/lessons/:id/video (cross-prefix) -> 403 Forbidden (PASS)
- [B.1-neg-unconf] PATCH /admin/lessons/:id/video (unconfirmed key) -> 400 Bad Request (PASS)
- [B.2-draft-404] POST /orders (draft course) -> 404 Not Found (PASS)
- [B.3-mint-proof] POST /orders/:id/payment-proof-url (own scope) -> 201 Created (PASS)
- [B.3-cross-mint] POST /orders/:id/payment-proof-url (cross order) -> 403 Forbidden (PASS)
- [B.3-cross-submit] POST /orders/:id/payment-proof (cross key) -> 403 Forbidden (PASS)
- [B.3-own-submit] POST /orders/:id/payment-proof (own key) -> 201 Created (PASS)
- [B.2-active-409] POST /orders (active enrollment duplicate) -> 409 Conflict (PASS)

2. Hasil Concurrency Race:

- race-double-register.mjs against deployed target -> Statuses: [409, 201], users count in DB = 1, Verdict: PASS.

3. Live Re-spot Paritas Dual-Target ala Wave F3 (11/11 PASS — 0 Mismatch):

Artefak tersimpan di .omo/evidence/xolvon-qa-endpoint-testing/resolusi/f3-respot-recheck-results.json:

- [S1] GET /courses catalog & structure: PASS (0 MISMATCH)
- [S2] GET /courses/<random> 404 envelope: PASS (0 MISMATCH)

- [S3] GET /auth/me unauthenticated 401: PASS (0 MISMATCH)
- [S4] GET /search empty query match 200: PASS (0 MISMATCH)
- [S5] GET /search query > 200 chars 400: PASS (0 MISMATCH)
- [S6] GET /home structure & sections: PASS (0 MISMATCH)
- [S7] GET /auth/me admin role & payload: PASS (0 MISMATCH)
- [S8] GET /admin/orders structure & envelope: PASS (0 MISMATCH)
- [S9] GET /admin/orders?status=invalid enum 400: PASS (0 MISMATCH)
- [S10] GET /admin/overview counts & keys: PASS (0 MISMATCH)
- [S11] GET /admin/overview unauthenticated 401: PASS (0 MISMATCH)

4. Wave F4 Scope & Secret Hygiene:

- Scope diff dibatasi secara ketat hanya pada area 9 blocker (auth, media, lessons, orders, projects, docs). Nol scope creep.
- Secret scan pada git diff commit: 0 secret / credential leak.
- Suite testing lokal: npm run lint (0 error), npm run test:esm (46/46 suites, 447/447 tests pass), npm run test:e2e (116/116 tests pass), npm run build (exit 0).

§KESIMPULAN FINAL & STATUS VONIS

Seluruh 9 item blocker dari laporan sebelumnya telah diselesaikan dan dibuktikan secara empiris:

1. **Build deployed PRE-FIX:** Teratasi. Backend deployed telah menjalankan build terbaru dengan seluruh perbaikan B1–B5 dan A1–A3.
 2. **Keluarga 502-POST deployed:** Teratasi. POST /projects (201 Created), POST /lessons/:id/resources (201 Created via migration resmi 0009).
 3. **Attach video ke lesson (Open Decision High):** Teratasi. Diimplementasikan via PATCH /admin/lessons/:id/video dengan validasi prefix, konfirmasi upload, dan audit log (DL-035).
 4. **Checkout policy (Open Decision High):** Teratasi. Ditolak 404 jika draft, ditolak 409 jika sudah ada enrollment aktif (DL-034).
 5. **Residual objectKey lintas-user (BUG-T9-01 residual):** Teratasi. Di-scope per user ID, live test cross-user ditolak 403 (DL-033).
 6. **Logout-window JWT <= 15 menit:** Diadjudikasi resmi sebagai Known Limitation V1 yang dapat diterima (DL-036 / docs/security.md).
 7. **Kontrak 201 vs 200 (BUG-T4-14/15):** Teratasi. Confirm upload konsisten 201 Created, read-url konsisten 200 OK (DL-037).
 8. **HEAD-check pada confirm-upload (BUG-T8-01):** Teratasi & Di-fix (DL-040). R2StorageService memvalidasi eksistensi fisik via HeadObjectCommand ke Cloudflare R2 sebelum mencatat metadata. Key non-existent ditolak 404 Not Found; objek nyata lolos 201 Created.
 9. **BUG-race-500 (concurrency constraint):** Teratasi. Pemetaan D1 UNIQUE constraint menghasilkan 409 Conflict yang bersih.
- ➔ **VONIS FINAL:** SIAP PRODUCTION dengan known limitation: [1. JWT logout window ≤15 menit karena stateless JWT (DL-036 / B.4)]

§ADDENDUM: ROTASI KREDENSIAL, MIGRATION RESMI, & RESOLUSI BUG-T8-01 (2026-09-14)

Laporan penutupan 3 item addendum tindak lanjut:

1. **Item 1 — Rotasi Kredensial Administrator:**
 - Password awal admin@xolvon.com (SuperSecretPassword123!) yang terekspos di log/transcript dan commit 9a6did7 telah dirotasi secara menyeluruh.
 - Password baru di-generate secara acak 32-karakter dan di-hash menggunakan Argon2id (m=65536, p=4, t=3).
 - Hash baru diaplikasikan pada D1 xolvon-staging dan xolvon-production. Seluruh 57 sesi admin lama di-purge dari tabel sessions.
 - Login dengan password lama terbukti GAGAL (HTTP 401 Unauthorized); login dengan password baru terbukti BERHASIL (HTTP 200 OK).
 - Sanitasi source code (README.md:473) dan test scripts (QA_ADMIN_PASSWORD). Disediakan .env.test.example (committed) dan .env.test (gitignored).
 - Insiden dan mitigasi dicatat resmi di docs/security.md (INC-2026-09-14) dan docs/decision-log.md (DL-038).
2. **Item 2 — Konversi Fix Skema Menjadi Migration Resmi:**
 - Fix course_resources.course_id dikonversi menjadi migration file resmi src/database/migrations/0009_course_resources_course_id.sql.
 - src/database/migrate.ts dilengkapi penanganan idempotent (duplicate column name).
 - Database production xolvon-production (99bf2fc5-...) dipetakan ke wrangler.jsonc (env.production).
 - Migrasi 0008_media_objects.sql dan 0009_course_resources_course_id.sql diterapkan ke production lewat wrangler d1 migrations apply xolvon-production --remote --env production.
 - Kedua database D1 (staging & production) 100% tersinkronisasi (✅ No migrations to apply!).
 - Re-test POST /lessons/:id/resources lolos dengan status 201 Created (14/14 tests pass). Dicalat di docs/architecture.md dan docs/decision-log.md (DL-039).
3. **Item 3 — Adjudikasi & Resolusi BUG-T8-01 (HEAD-check Storage):**
 - Perilaku masalah, aktor (strictly admin-only), dan dampak risiko dijelaskan secara eksplisit dan transparan.
 - Diputuskan Opsi (b): Di-fix sebelum production untuk memastikan zero ghost-media dan integritas metadata storage.
 - R2StorageService.confirmUpload menginisiasi HeadObjectCommand ke Cloudflare R2 dan melempar NotFoundException jika objek tidak ada (404).
 - LocalTestStorageService memverifikasi staged keys dan melempar NotFoundException jika unstaged.
 - Terverifikasi pada e2e test suite (117/117 pass) dan live re-verification script (14/14 pass):
 - Non-existent key ditolak dengan HTTP 404 (B.5-neg PASS).
 - Objek nyata di R2 lolos HEAD-check dan dikonfirmasi HTTP 201 (B.5-a PASS).
 - Objek video berhasil di-attach ke lesson HTTP 200 (B.1-pos PASS).
 - BUG-T8-01 resmi CLOSED / FIXED (DL-040) dan dihapus dari daftar known limitation.